

RESEARCH

Open Access



CTI-Thinker: an LLM-driven system for CTI knowledge graph construction and attack reasoning

Xiuzhang Yang¹ , Ruijie Zhong², Yuling Chen^{1,2*}, Guojun Peng³, Di Yao¹, Chaofan Chen¹, Chenyang Wang³, Dongni Zhang³, Yilin Zhou³ and Zixuan Yang¹

Abstract

With the increasing frequency of APT attacks, cyber defense urgently demands high-quality threat intelligence support. Cyber threat intelligence (CTI) knowledge graphs have demonstrated significant potential in aiding threat detection and behavioral reasoning. However, existing CTI data often suffer from unstructured formats, fragmented knowledge, a reliance on manual annotation, and limited semantic mapping to attack techniques. These limitations hinder the robustness and accuracy of downstream reasoning tasks (e.g., attack attribution and intent inference). Moreover, traditional information extraction methods struggle to generalize in scenarios involving cross-paragraph dependencies, emerging threats, and low-resource samples, exhibiting weaknesses in context awareness and sensitivity to prompt variations. To this end, we propose CTI-Thinker, a novel system that integrates large language models with semantic alignment to the ATT&CK framework for CTI knowledge graph construction and threat reasoning. First, CTI-Thinker leverages in-context learning and LoRA-based fine-tuning to extract structured threat entities and relations. Then, it adopts vector-based alignment strategies to unify heterogeneous expressions, enabling entity normalization and knowledge fusion for constructing a high-quality CTI knowledge graph. Finally, a GraphRAG-based reasoning engine is built by incorporating the structured knowledge graph and external ATT&CK resources into a retrieval-augmented generation (RAG) framework, enabling tactical-level inference and CTI-driven question answering. Experimental results demonstrate that CTI-Thinker accurately extracts threat entities and relations and constructs a reliable CTI knowledge graph. It also effectively infers attack intent and supports intelligent reasoning. The system outperforms state-of-the-art methods in precision, robustness, and generalizability, offering a scalable and semantically enriched solution for cyber threat analysis and defense.

Keywords Cyber threat intelligence, Large language model, Retrieval-augmented generation, Knowledge graph, Attack reasoning

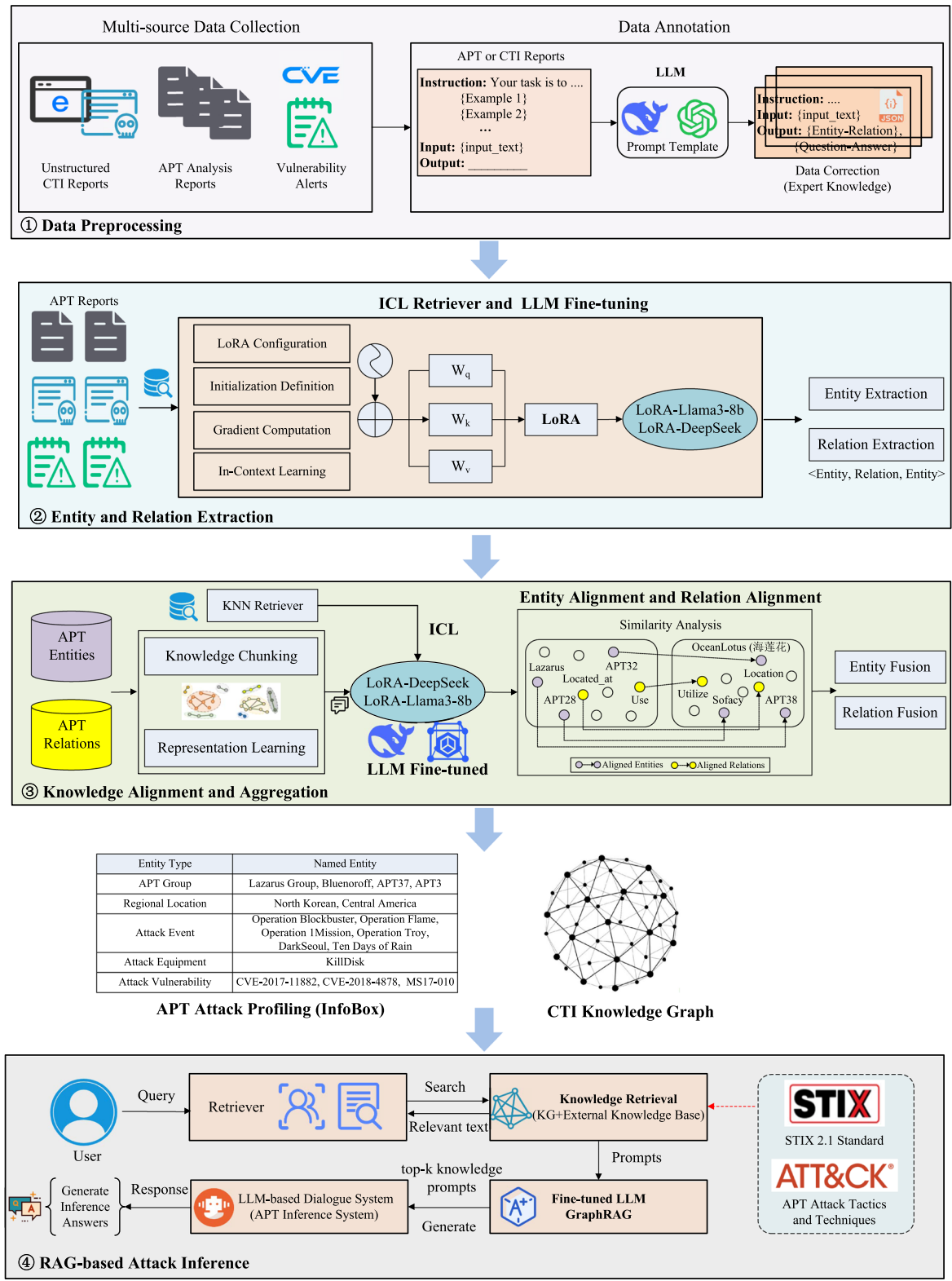
*Correspondence:

Yuling Chen

ylchen3@gzu.edu.cn

Full list of author information is available at the end of the article

Graphical abstract



Introduction

Recently, advanced persistent threats (APTs) (Yang et al. 2025), zero-day vulnerability exploitation (Rahimi et al. 2025), DDoS attacks (Tang et al. 2025), and PowerShell fileless attacks (Yang et al. 2023) have posed critical risks to national security, industrial production, and social stability. It is urgent to detect adversarial behaviors and implement proactive defense by leveraging threat intelligence knowledge. Cyber threat intelligence (CTI) refers to evidence-based knowledge of threats that documents critical information about cyber incidents or malicious activities, with the objective of supporting defense strategy formulation and adversarial behavior modeling (Ainslie et al. 2023; Hu et al. 2024). By extracting key entities (e.g., APT groups, attack tools, and vulnerability) along with their semantic relations from unstructured texts (e.g., security reports, alert logs, and threat bulletins), fragmented threat knowledge can be transformed into structured attack profiles and knowledge graphs, thereby enhancing the capacity of security systems to comprehend and reason over complex attack chains (Gao et al. 2021; Jo et al. 2022).

However, existing open-source CTI resources commonly suffer from issues such as unstandardized structure and fragmented knowledge. Also, they often rely excessively on expert annotations and lack deep semantic modeling of advanced adversarial tactics and techniques (Ainslie et al. 2023). These limitations significantly constrain their effectiveness in tasks such as attack attribution, intent inference, and intelligent question answering. Furthermore, many current approaches fail to fully exploit CTI resources, neglecting the automated extraction of tactics, techniques, and procedures (TTPs) and indicators of compromise (IOCs), which in turn undermines the robustness and intelligence of threat detection and attribution systems (Zhao et al. 2024). Therefore, it is imperative to develop an intelligent system capable of automatic knowledge extraction and complex attack reasoning to enable the efficient transformation of unstructured CTI texts into structured security knowledge, thereby supporting advanced semantic inference.

In the early stages, researchers primarily employed deep learning models (e.g., BiLSTM-CRF, BERT, and RoBERTa) and natural language processing (NLP) techniques to extract CTI entities and relations (Ranade et al. 2021; Yang et al. 2022). Several representative systems further integrated ontology-based multilingual entity extraction and knowledge graph updating, including CyberEyes (Fang et al. 2021), CSKG4APT (Ren et al. 2022), and SecureBERT (Aghaei et al. 2022). While these methods have shown promise in extracting threat-related information, their heavy reliance on manually annotated data limits adaptability to large-scale and multimodal

CTI corpora. Moreover, the separate modeling of entities and relations often fails to capture global semantic dependencies, resulting in error propagation and fragmented understanding. Also, the insufficient semantic alignment with TTPs restricts their effectiveness in supporting behavioral reasoning and high-level threat analysis.

With the rapid advancement of large language models, their superior performance in NLP tasks has significantly expanded the capabilities of security text processing. Equipped with strong capabilities in language understanding and contextual modeling, LLMs are able to perform complex semantic parsing even under zero-shot and few-shot scenarios, thereby significantly reducing reliance on annotated data and gradually facilitating the evolution of CTI from manual analysis to semantic understanding (Huang et al. 2025; Chang et al. 2024). Recent studies have begun integrating LLMs into CTI extraction tasks. For instance, CTINEXUS (Cheng et al. 2025) leverages in-context learning strategies to construct knowledge graphs under few-shot settings. LLM-TIKG (Hu et al. 2024) employs LoRA-based fine-tuning and triple generation to accomplish entity and TTP extraction. GPT-RE (Wan et al. 2023) reformulates relation extraction as a question-answering process and incorporates semantic reasoning to improve the structured output. These approaches introduce novel paradigms for CTI extraction and threat analysis, thereby accelerating the development of structured threat intelligence systems.

However, existing LLM-based threat intelligence extraction methods still face several challenges. First, some approaches focus on isolated entity or relation extraction tasks and lack unified modeling for both knowledge extraction and attack chain reasoning, which limits the construction of semantically complete CTI knowledge graphs. Second, real-world CTI corpora often contain a high degree of polysemy and ambiguity, and the absence of effective entity alignment and knowledge fusion techniques leads to semantic inconsistencies in the extracted knowledge. Third, some methods are highly sensitive to prompt formulation, prone to generating hallucinations, and exhibit limited capacity in attack chain reconstruction and deep reasoning due to the lack of graph-based structural assistance and insufficient handling of cross-paragraph dependencies and semantic inference.

To address the aforementioned challenges, we propose CTI-Thinker, a threat knowledge graph construction and reasoning system enhanced by large language models and ATT&CK semantic mapping. Centered around an LLM architecture, the system integrates in-context learning (ICL), LoRA-based fine-tuning, and a GraphRAG-based

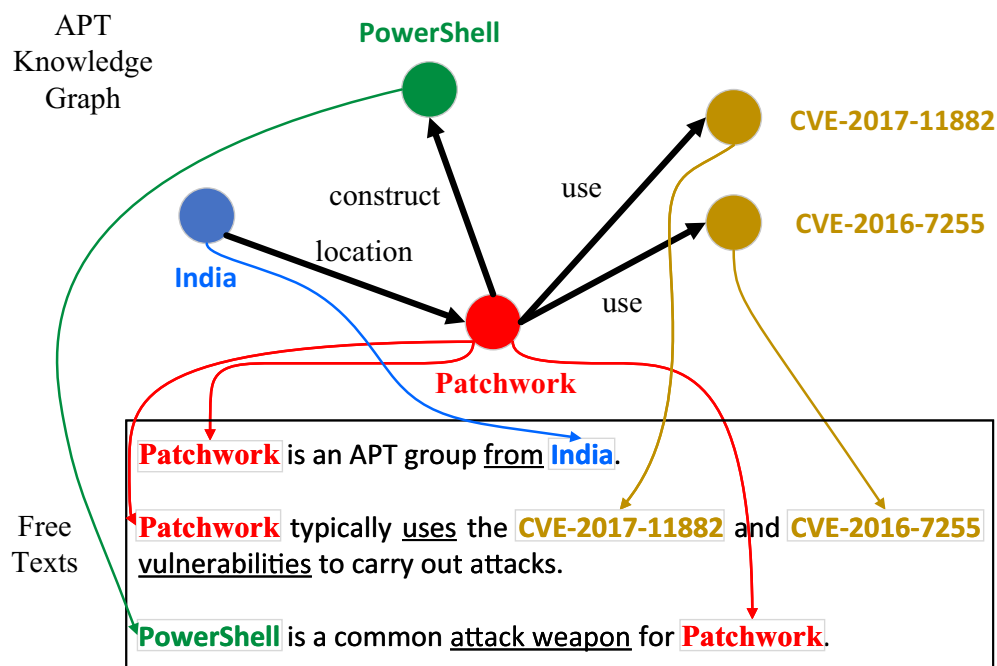


Fig. 1 An example of cyber threat intelligence knowledge graph construction

reasoning mechanism to systematically perform structured extraction of threat entities and relations, semantic alignment of entities, knowledge graph fusion, and deep reasoning at the level of tactics, techniques, and procedures. This framework significantly enhances the capability for automated threat knowledge extraction and improves the level of intelligent cybersecurity response. In summary, we make the following contributions:

- Key insights.** By integrating in-context learning (ICL), a LoRA-based LLaMA3-8B model, and retrieval-augmented generation (RAG) techniques into CTI knowledge graph construction and attack reasoning, we develop CTI-Thinker, a unified system capable of structured knowledge extraction, threat entity alignment, and attack chain inference. We summarize three key insights that guide our research. These insights address critical challenges and introduce innovative solutions for extracting threat knowledge and mapping ATT&CK TTPs, including: (i) addressing automatic CTI annotation and entity–relation extraction; (ii) developing entity alignment and knowledge fusion approaches tailored for heterogeneous threat documents from multiple sources; and (iii) designing a GraphRAG-based reasoning engine for tactical and technical question answering in APT attack scenarios.
- Innovative knowledge extraction algorithms.** We propose a threat entity and relation extraction algo-
- Innovative knowledge Alignment algorithms.** We further introduce a multi-granularity vector alignment strategy that couples contextual clustering with semantic vector alignment to address the polysemy of CTI terms and cross-sentence disambiguation. The approach fuses threat mentions across paragraphs and paraphrased expressions, thereby constructing a TTP-level knowledge graph that enhances the visualization and interpretability of attack contexts.
- Innovative attack reasoning engine.** We propose a GraphRAG-based attack chain reasoning module that leverages ATT&CK tactic–technique mappings and graph-enhanced retrieval techniques to construct semantically coherent, structurally explicit, and tactically complete representations of attack chains. This module enables TTP-level inference and interactive question answering, effectively mitigating hallucination risks and logical inconsistencies commonly observed in the native outputs of large language models. It also significantly enhances the system's capability to provide interpretable understanding of APTs.

- **Systematic evaluation and open-source dataset.** We constructed a comprehensive CTI dataset encompassing diverse entity and relation types, which has been released as an open-source resource on GitHub.¹ Through systematic experiments, we demonstrate that CTI-Thinker outperforms existing state-of-the-art methods in CTI entity and relation extraction. The proposed approach effectively constructs CTI knowledge graphs and generates detailed attack profiles. Moreover, empirical results validate that CTI-Thinker enables intelligent question answering for APT attack scenarios and supports the inference of adversarial tactics and techniques aligned with the ATT&CK framework, thereby exhibiting enhanced generalization and practical applicability. Our research offers substantial academic and real-world contributions to advancing automated threat knowledge extraction and reasoning.

Background and related work

This section provides a concise overview of recent works in extracting cyber threat intelligence (CTI).

Threat entity recognition and relation extraction

A knowledge graph (KG) is a multi-relational graph structure where entities are represented as nodes and semantic relationships as edges. It is designed to model real-world concepts and their interrelations, enabling the organization, storage, and reasoning over complex and heterogeneous knowledge (Hogan et al. 2021). As a key approach for the structured representation of complex information, KGs have been widely applied in domains including search engines (Xiong et al. 2017), healthcare (Piya and Beheshti 2025), industrial control system (Li et al. 2024a), and social network analysis (Abu-Salih et al. 2021). These advances provide a solid foundation for their integration into cybersecurity (Ainslie et al. 2023). Threat entity recognition aims to identify key information entities (e.g., APT groups, malware, attack techniques, or vulnerabilities) from unstructured cybersecurity texts. Relation extraction captures semantic associations (e.g., use, attack) among these entities, constructing the relational structures of CTI knowledge graphs (Ainslie et al. 2023). Figure 1 illustrates how structured triples can be extracted from free-text descriptions. For example, Patchwork using PowerShell and exploiting CVE-2017-11882 can be represented as a knowledge graph to support downstream tasks (e.g., semantic reasoning or attack detection).

Traditional DL-based CTI Extraction. Previous research on CTI extraction methods has primarily relied on natural language processing and deep learning (DL) techniques, including conditional random field (CRF), convolutional neural networks (CNN), bidirectional long short-term memory network (BiLSTM), and Transformer-based architectures (Zhao et al. 2024). These approaches focused on classifying cybersecurity entities and their semantic relations. CyberEyes (Fang et al. 2021) is a GCN-based cybersecurity entity recognition system that models non-local dependencies through graph representations of inter-entity relationships. CyberRel (Guo et al. 2021) reformulated entity recognition and relation extraction as a unified multi-sequence labeling task. CSK-G4APT (Ren et al. 2022) leveraged a multilingual BERT-based entity recognition model to support automatic graph updates, APT profiling, and attribution analysis. Yang et al. (2022) proposed an APT entity recognition model based on a BERT-BiLSTM-CRF architecture and constructed structured profiles to represent APT groups. In addition, Mouiche and Saad (2025) conducted a comprehensive review of threat entity recognition and relation modeling methods, offering a systematic reference framework for subsequent research.

Bert-based Variants for CTI Extraction. Since the introduction of Bert, its bidirectional semantic modeling has significantly enhanced the extraction of complex language patterns, outperforming LSTM and CNN models in handling long-range dependencies. Subsequently, various Bert-based pre-trained variants have been developed to further improve the performance of CTI extraction. Chen et al. (2021) proposed the Joint Bert model that integrated Bert embeddings with LSTM, ID-CNN, and CRF architectures to improve the recognition of software-related entities. CyBERT (Ranade et al. 2021), a domain-adapted model pre-trained on cybersecurity-specific corpora, enhanced contextual representation capabilities and enabled effective entity recognition in cybersecurity texts. Similarly, Aghaei et al. (2022) introduced SecureBERT that can recognize security entities and perform threat text classification tasks.

TTP-based Threat Behavior Extraction. However, traditional approaches often overlook the logic of the attack chain in cyber intrusions, making it difficult to effectively capture the tactics, techniques, and procedures (TTPs) of adversaries. To address this limitation, several knowledge extraction methods have been proposed to model attack processes and behaviors. Chen et al. (2025a) introduced EMGE that enhanced cross-sentence relation extraction through semantic enrichment and connection modeling. TTPDrill (Husari et al. 2017) combined keyword-based retrieval and semantic matching to extract TTPs and map them to ATT&CK.

¹ <https://github.com/eastmountyxz/CTI-Thinker>.

rcATT (Legoy et al. 2020) reformulated relation extraction as a multi-label classification task and leveraged the ATT&CK framework to enhance model discrimination. Satvat et al. (2021) proposed EXTRACTOR, a system that constructed attack path graphs using semantic role labeling to support traceability and correlation analysis of malicious activities. LADDER mapped extracted attack patterns to the ATT&CK framework based on semantic similarity, enabling large-scale threat extraction from CTI reports (Alam et al. 2023).

In summary, current CTI extraction works utilize deep learning (e.g., Bert-BiLSTM-CRF), multilingual modeling, joint learning, and cross-sentence relation modeling to extract threat-related entities and relations. Subsequent research focuses on extracting ATT&CK labels from CTI reports and constructing attack path graphs using multi-label classification. However, these methods exhibit several limitations. First, they heavily depend on manually annotated data, which limits their adaptability to real-world CTI corpora. Also, the decoupled modeling of entities and relations restricts global semantic integration, resulting in higher false-positive rates and limited robustness. Moreover, traditional approaches perform poorly in aligning adversarial TTPs and fail to infer attack behaviors. To address these challenges, LLM-based approaches for threat knowledge extraction have gradually emerged.

Large language models and retrieval-augmented generation techniques

Large Language Models. With the rapid advancement of deep learning, large language models (LLMs) have demonstrated strong capabilities in language modeling, semantic understanding, and contextual reasoning. Representative models include the BERT family (e.g., BERT, RoBERTa (Liu et al. 2019)), the GPT series (e.g., GPT-3, GPT-4 (Achiam et al. 2023)), and open-source foundation models (e.g., LLaMA (Touvron et al. 2023) and DeepSeek (Guo et al. 2025a)). In the cybersecurity domain, LLMs have shown great promise in extracting and reasoning over cyber threat intelligence. They can effectively identify entities, events, and relations from unstructured text, supporting the construction of extensible CTI knowledge graphs. Furthermore, their zero-shot and few-shot learning capabilities reduce the dependence on annotated data, advancing automated and intelligent threat analysis (Shi et al. 2024).

However, current LLMs face several challenges in practical deployment. First, lacking external knowledge retrieval, they are prone to hallucinations that deviate from factual information (Ji et al. 2023; Huang et al. 2025). Second, their generation often lacks controllability, interpretability, and stability, particularly in cybersecurity

contexts with high contextual interference (Shi et al. 2023). Moreover, their understanding of threat semantics remains shallow, relying on pattern matching and struggling with polysemy, ambiguity, and subtle semantic variations, which limits deep reasoning and attack chain modeling (Srikanth et al. 2024).

Retrieval-Augmented Generation. To address the above limitations, retrieval-augmented generation (RAG) has emerged as a promising solution (Lewis et al. 2020). RAG introduces an external retrieval module that semantically fetches relevant information from knowledge bases and combines it with the input for generation. This enhances factual accuracy, contextual completeness, and output controllability. RAG has shown strong performance in knowledge-intensive tasks and is increasingly applied to cybersecurity text processing (Rajapaksha et al. 2024). Recently, Microsoft proposed GraphRAG (Edge et al. 2024), which integrates graph structures and community-based partitioning to model long-range cross-document dependencies. This advancement supports APT chain reasoning, TTP extraction, and cross-source threat attribution.

In summary, LLMs offer strong language understanding and generation capabilities, enabling structured threat intelligence representation and cybersecurity knowledge graph construction. The RAG framework further enhances factual consistency and contextual coherence. Accordingly, we propose a CTI entity and relation extraction approach that integrates LLM and RAG, along with a knowledge graph reasoning engine to support APT attack chain inference.

LLM-based threat intelligence extraction

General-domain Knowledge Extraction with LLMs. LLMs were initially applied to general-domain knowledge extraction, demonstrating strong performance in automated KG construction on benchmark datasets. Representative works include SAC-KG (Chen et al. 2024a), which employed structure-aware prompts for triple generation; LKD-KGC (Sun et al. 2025), an unsupervised framework leveraging inter-document semantics; and iText2KG (Lairgi et al. 2024), which adopted multi-round extraction and incremental graph building. To address data scarcity, Liu et al. (2024) proposed a zero-shot self-prompting strategy for relation extraction, while ACKG-LLM (Wang et al. 2025) ensured scalability through generative capabilities without retraining. These methods have achieved notable advances in entity recognition and triple generation, supporting high-quality KG construction. However, their reliance on open-domain corpora and standardized datasets limits applicability to complex vertical domains such as cybersecurity, which features domain-specific

unstructured texts, terminological ambiguity, and implicit adversarial tactics. Consequently, researchers have begun leveraging LLMs for CTI extraction to advance structured representation and automated reasoning in security contexts.

LLM-Based CTI Extraction. In the early stages, researchers primarily used unfine-tuned large language models for CTI extraction. Liu and Zhan (2023) constructed a CTI knowledge graph using ChatGPT and showed its advantage over traditional methods such as AttackKG (Li et al. 2022). Siracusano et al. (2023) introduced an open benchmark dataset and a structured extraction framework named aCTIon, which utilized GPT-3.5 to identify threat elements. GPT-RE (Wan et al. 2023) reformulated relation extraction as a QA task, incorporating a diversity control mechanism to address relation sparsity with gold label-induced reasoning. Fieblinger et al. (2024) explored the challenges of using vanilla LLMs (e.g., LLaMA) and KGs for extracting actionable intelligence. SEvenLLM (Ji et al. 2024) proposed a multilingual instruction-based framework for cybersecurity event analysis. Zhou et al. (2025) developed AEKG4APT, which extracted APT-related knowledge and built a targeted knowledge graph. While unfine-tuned LLMs support automated entity and relation extraction. However, they still suffer from significant limitations, such as sparse relation types, weak reasoning capabilities, and limited scalability.

Fine-Tuned LLM-Based CTI Extraction. To overcome existing limitations, recent studies have explored fine-tuning strategies and prompt optimization to enhance the accuracy and robustness of CTI extraction (Chen et al. 2024b). AECR (Chen et al. 2025b) employed a fine-tuned LLM to extract attack techniques and integrated automatic verification mechanism to reduce hallucinations. LLM-TIKG (Hu et al. 2024) combined LoRA fine-tuning with large-scale models to build knowledge graphs from unstructured CTI and extract TTPs, effectively linking IoCs to high-level attack patterns. CTI-Bench (Alam et al. 2024) provided a benchmark for evaluating LLMs in CTI applications. LLMcloudHunter (Schwartz et al. 2025) generated candidate detection rules from textual and visual OSCTI data. In addition, LLM-based correlation techniques have been applied to attack detection (Du et al. 2024), autonomous cyber defense (Loevenich et al. 2025), incident QA (Sufi 2024), and phishing detection (Li et al. 2024b). However, these methods still struggle with deep semantic understanding and long-document extraction, often resulting in semantic drift, structural fragmentation, and redundant expressions.

CTI Extraction Using In-Context Learning in LLMs. Existing CTI extraction methods often struggle

to identify attack-level information (i.e., TTPs) due to limited contextual semantic awareness and poor handling of long-form text. The average CTI report contains about 408 words, frequently exceeding the context window of most LLMs (Xu et al. 2024). To overcome these challenges, enhanced approaches combining In-Context Learning (ICL) with semantic augmentation have been proposed. Representative methods include IntelEX, c-ICL, AttackKG+, and CTINEXUS. IntelEX (Xu et al. 2024) leveraged ICL and an LLM-based judgment module to extract TTPs from unstructured text. AttackKG+ (Zhang et al. 2025) used automated LLM-driven modeling to construct attack graphs, addressing semantic redundancy and structural fragmentation. The c-ICL framework (Mo et al. 2024) incorporated structure-aware prompts and contrastive learning to improve triple extraction quality. CTINEXUS (Cheng et al. 2025) optimized ICL for few-shot cybersecurity knowledge graph construction, supporting long-distance relation prediction in complex CTI reports. LLM-based methods have advanced TTP extraction and improved semantic structure. However, several critical challenges still persist. These include weak cross-paragraph reasoning, hallucinations, and high sensitivity to prompt design, which reduce robustness and reasoning accuracy. To address these issues, recent research has explored threat reasoning approaches based on Retrieval-Augmented Generation (RAG) and graph-enhanced techniques.

Enhanced Reasoning with RAG and Graph-based Techniques. The RAG paradigm has significantly improved retrieval accuracy and response generation in threat intelligence extraction. IntelEX (Xu et al. 2024) adopted GraphRAG to generate attack steps for red team simulation. APTSniffer (Xu et al. 2025), an encrypted APT traffic detection model, combined LLMs with RAG to transform raw traffic into interpretable reasoning traces. IntellBot (Arikkat et al. 2024), a security chatbot based on LLMs and RAG, supported threat intelligence and incident response. MalGTA (Guo et al. 2025b) combined dynamic sandbox with RAG to analyze malware tactics aligned with the ATT&CK framework, improving analytical accuracy and interpretability. Rajapaksha et al. (2024) applied a RAG-based QA model to assist in attack investigation and attribution. Jeon et al. (2024) compared Label Property Graph (LPG) and RDF graph models for RAG-based threat tracing. DroidTTP (Arikkat et al. 2025) employed RAG and LLM fine-tuning to map Android malware behaviors with ATT&CK. Fayyazi et al. (2024) contrasted supervised fine-tuning of encoder-only LLMs with RAG-based approaches for decoder-only LLMs in threat analysis.

Table 1 Comparison of Representative Works on CTI Extraction

Related work	Techniques	Focus	Automatic	RAG Reasoning	ATT&CK Mapping	Entity alignment	In-context learning	Robustness
Poirot (Milajerdi et al. 2019)	provenance graph graph pattern matching	cyber threat hunting	×	×	×	✓ (graph alignment)	×	×
Yang et al. (2022)	Bert-BiLSTM-CRF clustering algorithm	APT profile generation	×	×	×	✓	×	○
CyBERT (Ranade et al. 2021)	Bert masked language modeling	cybersecurity entity recognition	×	×	×	×	×	○
SecureBERT (Aghaei et al. 2022)	Bert improved pre-trained method	CTI extraction	×	×	×	×	×	○
CSKG4APT (Ren et al. 2022)	deep learning expert knowledge	APT KG construction APT attribution	×	×	×	×	×	×
TTPDrill (Husari et al. 2017)	natural language processing information retrieval	CTI extraction	×	×	✓	×	×	×
AttackKG+ (Zhang et al. 2025)	LLM + ICL rewriter, parser identifier, summarizer	CTI extraction attack graph construction	○	×	×	×	✓	○
IntelEX (Xu et al. 2024)	LLM + ICL + RAG chunking LLM-as-a-judgment	CTI extraction TTPs and IOCs extraction attack behavior simulation	○	✓	✓	×	✓	○
LLM-TIKG (Hu et al. 2024)	fine-tuned LLM + LoRA	CTI KG construction	○	×	×	×	×	○
DroidTTP (Arikkat et al. 2025)	fine-tuned LLM + RAG SHAP-based model	Android TTPs extraction	○	✓	✓	×	×	○
Our method CTI-Thinker	fine-tuned LLM + ICL GraphRAG entity alignment algorithm attack reasoning engine multi-stage integration framework	CTI extraction CTI KG construction attack behavior reasoning	✓	✓	✓	✓	✓	✓

In this table, ✓ stands for fully cover or strong capability in the corresponding aspect. ○ stands for partial cover or possesses limited capability in that aspect. × means cannot cover or lack of corresponding capability. **Automatic** means automated end-to-end processing. **RAG Reasoning** means retrieval-augmented reasoning. **ATT&CK Mapping** means mapping to MITRE ATT&CK. **Entity Alignment** means cross-sentence/document entity resolution and disambiguation. **In-context Learning** means example-based prompting. **Robustness** means stability on long/noisy texts. A higher level of automation corresponds to less reliance on manual data annotation and expert knowledge

Summary and research motivation

LLM-based threat intelligence extraction has made significant progress, particularly through the integration of ICL and RAG. However, most existing methods remain confined to isolated tasks (e.g., entity recognition or relation extraction) and lack a unified framework for threat knowledge modeling and reasoning. Challenges such as fragmented entity alignment, limited semantic integration, and the absence of modules for knowledge fusion, disambiguation, and attack chain reconstruction persist.

Furthermore, their reliance on lengthy prompt interactions leads to high token consumption and poor scalability. To overcome these limitations, we propose CTI-Thinker, a system that integrates semantic enhancement with advanced inference capabilities. CTI-Thinker unifies entity recognition, entity alignment, relation extraction, and ATT&CK-based semantic reasoning. A dedicated alignment algorithm resolves polysemy in threat terms, while a hybrid ATT&CK-guided and RAG-driven mechanism reconstructs attack knowledge,

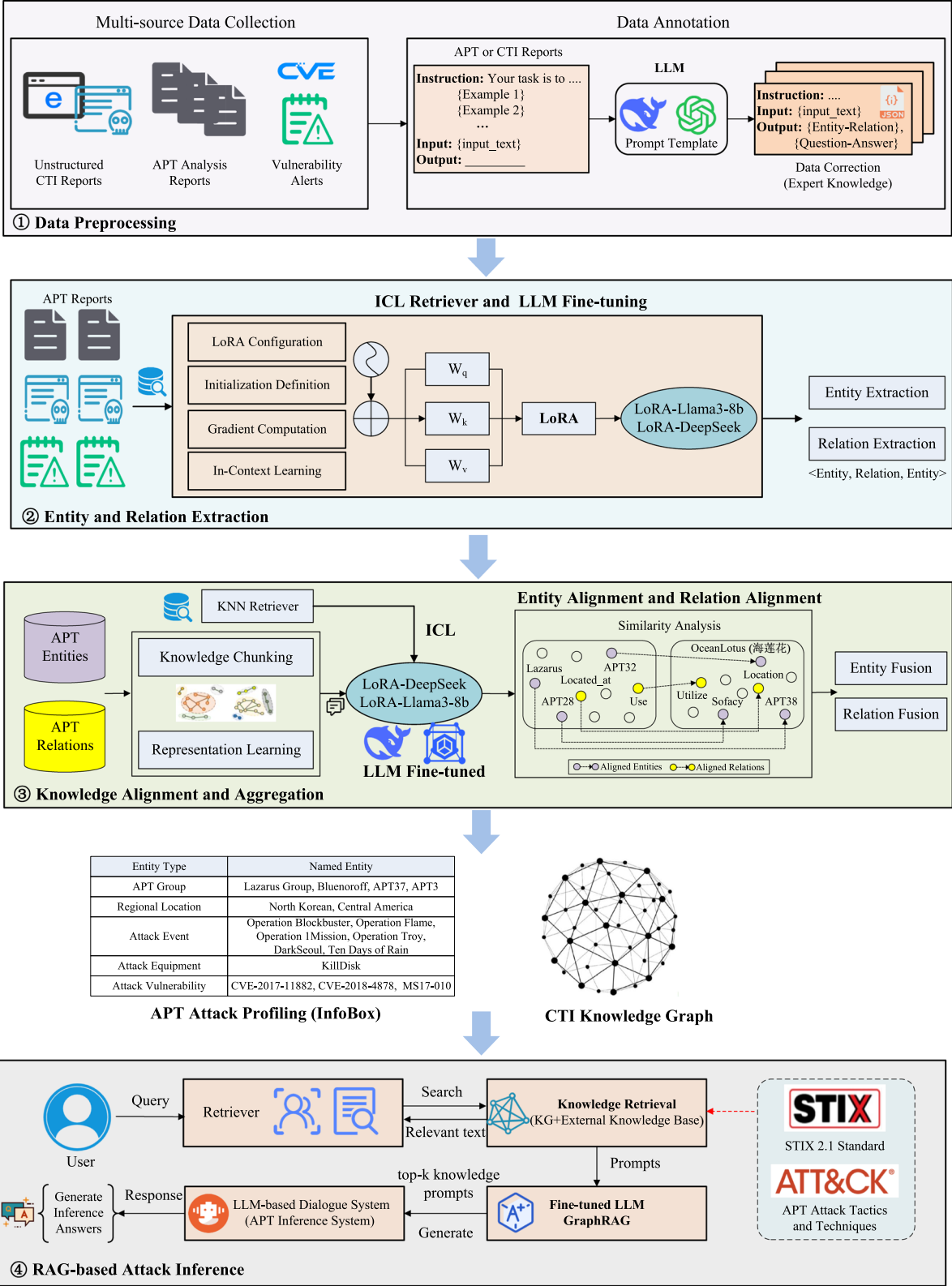


Fig. 2 The architecture of CTI-Thinker

mitigating hallucinations and improving TTP extraction. Leveraging in-context learning and fine-tuned LLMs, the system reduces prompt overhead and enhances extraction efficiency, demonstrating strengths in semantic accuracy, knowledge completeness, and reasoning interpretability.

This section also presents a systematic comparison of representative CTI extraction approaches, as summarized in Table 1, across dimensions such as technique type, task focus, automation, reasoning ability, alignment, contextual learning, and robustness. Our analysis indicates that traditional deep learning methods depend heavily on expert features, lack contextual modeling, and exhibit limited robustness, making them unsuitable for handling structurally fragmented and semantically ambiguous CTI texts. Although recent LLM-based methods improve extraction performance, they still fall short in aligning with the ATT&CK framework and supporting attack chain reconstruction. Hallucinations and ambiguity remain unsolved. In contrast, CTI-Thinker offers a unified solution with strong contextual understanding, structural integration, and semantic reasoning, advancing CTI extraction from shallow recognition to deeper comprehension and inference.

Model design and implementation

Section 3 introduces the overall framework of CTI-Thinker, followed by a detailed overview of the implementation processes for each stage and its corresponding algorithms.

Overview

To enhance the extraction of cyber threat intelligence and the reasoning of attack behaviors, we innovatively design and implement CTI-Thinker. CTI-Thinker is an LLM-driven system for CTI extraction and reasoning that incorporates ATT&CK-based semantic mapping. It leverages in-context learning and fine-tuned LLMs to automate knowledge extraction, employs knowledge alignment to integrate threat profiles, and utilizes GraphRAG to enable question answering and attack scenario reasoning. As illustrated in Fig. 2, the overall architecture of CTI-Thinker comprises four key modules, which are described in detail below.

Data Preprocessing. This stage aggregates multi-source CTI data, including unstructured CTI reports, APT analysis documents, and vulnerability alerts. Prompt templates are constructed using LLMs to guide the generation of structured outputs (e.g., entities, relational triples, or QA pairs). The generated results are manually reviewed and refined based on expert knowledge. This process yields high-quality, instruction-tuned annotated

CTI corpora, thereby providing standardized inputs for downstream information extraction tasks.

Entity and Relation Extraction. To enhance the recognition of key entities and semantic relations within CTI-related corpora, large language models (e.g., LLaMA3-8b and DeepSeek) are fine-tuned using Low-Rank Adaptation (LoRA) techniques. In addition, an in-context learning (ICL) strategy is adopted, where a K-nearest neighbor (KNN) retriever embeds current and candidate reports into a high-dimensional space and selects the top-k most similar samples to construct customized prompt templates. Then, the fine-tuned model outputs structured relational triples in the form of (entity, relation, entity), covering key elements such as APT groups, attack methods, and targeted victims. These outputs serve as foundational semantic units for subsequent knowledge integration and reasoning.

Knowledge Alignment and Aggregation. This stage takes entity–relation triples as input and applies language model and knowledge chunking for representation learning. Using LoRA-tuned models and ICL, CTI entities and relations are coarsely grouped into semantically similar clusters. Vector similarity is used to align differing expressions of the same concepts. CTI-Thinker resolves ambiguity and redundancy by consolidating various mentions that refer to the same cybersecurity entities or relationships, thereby enabling effective threat knowledge integration (as illustrated in stage (3) of Fig. 2). The system subsequently auto-generates a structured CTI InfoBox encompassing key information (e.g., threat actors, geographic scope, attack events, tools, and vulnerabilities). Such output serves as the foundation for constructing a high-quality CTI knowledge graph, providing semantic support for threat reasoning and query tasks.

RAG-based Attack Inference. A reasoning framework based on Retrieval-Augmented Generation (RAG) is constructed to support automated cyber threat inference. Upon receiving a user query, the retriever module retrieves relevant external knowledge and graph-based information, which are subsequently used by the GraphRAG model to generate high-quality reasoning prompts. The fine-tuned LLM integrates structured knowledge graph content with contextual cues to produce CTI inference results compliant with STIX 2.1 and ATT&CK standards. The resulting system functions as an intelligent question-answering platform for automated APT threat analysis, enabling accurate reasoning over tactics, techniques, and procedures (TTPs), and mapping them to corresponding ATT&CK phases. CTI-Thinker enhances situational awareness and supports strategic decision-making in cybersecurity defense operations.

**Prompt Template:**

You are an intelligent assistant specializing in APT threat intelligence analysis, with advanced expertise in cybersecurity, entity recognition, and relation extraction. Based on the following instructions, perform structured extraction for each input threat intelligence sentence, identifying only the specified entity and relation types, and output the results in standard JSON format.

**Entity Recognition Prompt:**

The task requires the identification of the following entity types:

- (1) **Attacker:** The threat actor or APT group initiating the attack (e.g., Lazarus, APT28).
- (2) **Target:** The victim organization or affected department (e.g., Sony, a government agency).
- (3) **Technique:** Attack techniques or methods employed by the APT group (e.g., SQL injection, spear phishing, XSS).
- (4) **Equipment:** Open-source or custom-built tools used in intrusion or exploitation (e.g., Metasploit, Gh0st).
- (5) **Vulnerability:** The specific CVE identifier or vulnerability name exploited in the attack (e.g., CVE-2017-11882).
- (6) **File:** Names of malicious files used in the attack (e.g., cmd132.exe, Agent.btz).
- (7) **Industry:** The targeted sector or industry (e.g., finance, education).
- (8) **Region:** The geographical focus of the attack or the region/country associated with the attacker (e.g., North Korea, Russia).
- (9) **MalwareFamily:** The malware family used in the attack (e.g., PlugX, Emotet).
- (10) **Indicator:** Indicators of compromise (IOCs), including malicious URLs, IP addresses, file hashes, and C&C.
- (11) **Software:** Software platforms exploited during the attack (e.g., Microsoft Word, Firefox, WinRAR, PDF Reader).
- (12) **ATT&CK:** The technique ID from the MITRE ATT&CK framework (e.g., T1129, T1082, T1027).

**Relation Extraction Prompt:**

You are required to extract only the following relation types:

- (1) **Alias_of:** Indicates different names for the same attacker or tool. e.g., <Darkhotel, Alias_of, APT-C-06>
- (2) **Related_to:** Indicates a potential or uncertain relationship between two entities. e.g., <Attacker1, Related_to, Attacker2>
- (3) **Use:** Represents a usage relationship between entities, an attacker using a tool. e.g., <Attacker1, Use, Tool/Equipment>
- (4) **Target_at:** Denotes the target of an attack, which can be a region or industry. e.g., <Attacker1, Target_at, Financial>
- (5) **Exploit:** Indicates that an attacker or tool exploits a specific vulnerability. e.g., <Attacker1, Exploit, CVE-2017-11882>
- (6) **Develop:** Represents the development relationship between an attacker and a tool or malware. e.g., <Attacker1, Develop, Tool1>
- (7) **Located_at:** Describes the geographic or organizational location of an attacker or entity. e.g., <DustSquad, Located_at, Russia>
- (8) **Belongs_to:** Indicates that a tool, file, or malware is affiliated with a family or group. e.g., <Tool1, Belongs_to, Malware1>
- (9) **Indicate:** Signifies that an Indicator points to a related attacker, malware, or IOC. e.g., <Indicator1, Indicate, APT28>
- (10) **Utilize:** Indicates that an attacker uses a specific software application in cyber operations. e.g., <Attacker1, Utilize, Software1>
- (11) **Employ:** Denotes the use of a specific ATT&CK technique by an attacker. e.g., <APT28, Employ, T1027 [Obfuscated Files or Information]>

**Instruction Requirements:**

You will receive multiple threat intelligence texts, each in the form of a sentence. For each sentence, upon successful identification of entities and their relations, output one standardized JSON object in the following format:

- (1) If entities and at least one of the specified 11 relation types are identified, use:


```
{
  "instruction": "Original sentence",
  "input": null,
  "output": "Entities: (Name, Type), (Name, Type)... \n Relations: (Entity1, Relation, Entity2), (Entity1, Relation, Entity2)..."
}
```
- (2) If only entities are identified but no relation exists among them, use:


```
{
  "instruction": "Original sentence",
  "input": null,
  "output": "Entities: (Name, Type), (Name, Type)... \n Relations: No relevant relation"
}
```
- (3) If no relevant entities or relations are identified, use:


```
{
  "instruction": "Original sentence",
  "input": null,
  "output": "No relevant entities or relations identified"
}
```

Important Notes:

Only the specified 12 entity types and 11 relation types must be extracted. Each sentence must correspond to exactly one standard JSON object. The output must be structurally clear, semantically accurate, and ready for direct integration into security systems.

Fig. 3 Prompt templates for threat intelligence annotation and knowledge extraction

LLM-based threat data annotation

To construct a structured and high-quality CTI knowledge graph, the CTI-Thinker system implements a comprehensive pipeline encompassing data collection, preprocessing, and LLM-based annotation, aiming to automate the extraction of key entities and relational information from threat intelligence corpora.

The system fully accounts for the heterogeneity and diversity of cyber threat intelligence sources. Data is collected from a wide range of channels, including APT analysis reports published by major security vendors (e.g., FireEye, QiAnXin, 360, and Kaspersky), threat event and vulnerability alerts from open-source intelligence communities, as well as technical blogs and

cybersecurity research consultancies. A customized web crawler is employed to extract threat intelligence from these various sources, with extraneous elements such as advertisements removed to ensure the semantic integrity and usability of the collected content. To enhance LLM processing, raw documents are preprocessed through paragraph segmentation, content categorization, and data cleaning. Each paragraph is further split into sentence-level units suitable for LLM input. Irrelevant elements (e.g., formatting symbols and footnotes) are removed using text-cleaning techniques to ensure input consistency and readability.

In the data annotation module, large language models (i.e., LLaMA3-8b, DeepSeek, and ChatGPT) are employed to construct standardized prompt templates, guiding the labeling of specific entity and relation types under few-shot learning settings. As detailed in Fig. 3, twelve common entity types are defined based on the STIX 2.1 specification and APT domain characteristics, including *Attacker*, *Target*, *Technique*, *Equipment*, *Vulnerability*, *Malicious File*, *Industry*, *Region*, *Malware Family*, *Indicator*, *Software*, and *ATT&CK*. Additionally, eleven relation types are designed to capture semantic associations between entities, including *Alias_of*, *Related_to*, *Use*, *Target_at*, *Exploit*, *Develop*, *Located_at*, *Belongs_to*, *Indicate*, *Utilize*, and *Employ* (as detailed in Fig. 3). For each sentence, the model extracts only the entities and relations relevant to the target schema and outputs the result in a standardized JSON triple format (instruction, input, output), ensuring reusability and ease of parsing. In cases where no valid entity or relation is identified, a predefined annotation format is still

produced to maintain output consistency across the model's responses.

Given the potential for large language models (LLMs) to produce overgeneralized or hallucinated outputs in certain scenarios, expert knowledge is incorporated to review and refine the initial annotations. This manual verification step helps enhance the overall quality of the annotated data. In addition, model fine-tuning is performed to progressively improve the LLM's ability to recognize entity boundaries, contextual semantics, and domain-specific terminology within CTI corpora. These enhancements collectively provide a reliable data foundation for downstream knowledge graph construction and attack reasoning.

In-context learning and LLM fine-tuning for entity and relation extraction

To enhance the extraction of threat entities and their semantic relations, we design a novel knowledge extraction framework that synergistically combines in-context learning with fine-tuned large language models. The overall architecture of the proposed method is depicted in Fig. 4.

Split and Extract Threat-Related Sentences. Our system first automatically identifies and extracts threat-related sentences from raw CTI reports to construct a structured CTI corpus. These extracted sentences serve as the foundation for subsequent prompt template construction and example retrieval.

In-Context Learning–Based Retrieval of CTI Semantic Samples. To enhance the generalization and data efficiency of LLMs in CTI extraction tasks,

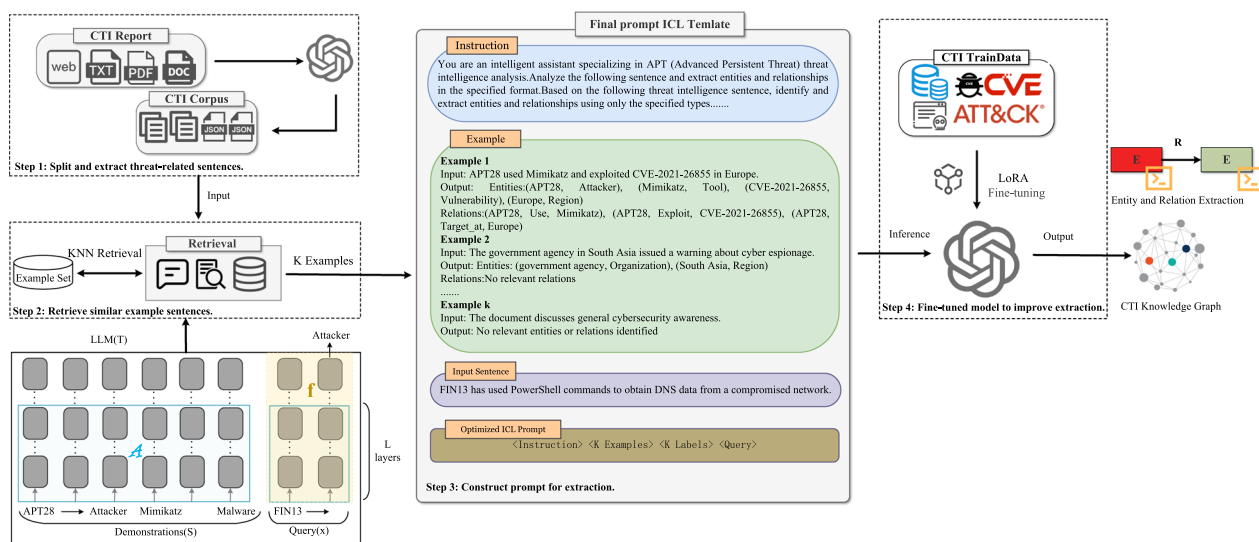


Fig. 4 The architecture for entity and relation extraction based on in-context learning and LLM

CTI-Thinker introduces an in-context learning (ICL) mechanism based on semantic similarity to support the structured extraction of threat entities and relations. Unlike conventional supervised learning that relies on parameter updates through backpropagation, ICL preserves model parameters and instead guides inference by constructing high-quality prompts. This approach enables the model to perform analogy-based reasoning and accurately predict structured outputs for unseen samples.

CTI-Thinker embeds annotated CTI examples into a high-dimensional vector space and stores them in a demonstration vector repository. A k-nearest neighbors (KNN) retriever is then employed to identify semantically relevant examples by computing the cosine similarity between the semantic vector of the input sentence v_x and each example vector in the repository, as defined in Eq. (1):

$$\text{Sim}(x, s_i) = \cos(v_x, v_{s_i}) = \frac{v_x \cdot v_{s_i}}{\|v_x\| \times \|v_{s_i}\|} \quad (1)$$

CTI-Thinker selects the top-k semantically similar examples to construct a demonstration set, ordered by ascending similarity to prioritize relevant instances and mitigate confirmation bias. This strategy enables the ICL mechanism to capture input–output structural alignment and infer latent extraction patterns through demonstration-based reasoning without parameter updates. Consequently, the model achieves efficient and accurate knowledge extraction with strong transferability across heterogeneous threat reports and ontologies.

Construct ICL Prompt for Knowledge Extraction.

We construct a standardized ICL prompt consisting of three components: (1) a task instruction that explicitly defines the target information types and output format; (2) k semantically relevant examples, each comprising a CTI input sentence paired with its annotated knowledge triples; and (3) the current input sentence to be processed. The final prompt is formulated as follows:

$$\text{Prompt} = \langle \text{Instruction}, \text{Examples}_{1:k}, \text{Query} \rangle \quad (2)$$

The instruction component clearly defines the task objective, which is to extract specific types of entities and relations, as well as the required output format. Representative prompt templates are shown in Fig. 3. The example section presents standardized input–output pairs, and the query corresponds to the current threat sentence to be processed. This prompt design reformulates the complex triple extraction task into a question-answer format that aligns with the operational mode of large language models (i.e., Prompt-as-QA),

thereby significantly improving both inference efficiency and extraction quality.

Fine-Tuned LLM for Entity and Relation Extraction.

To enhance the model's domain-specific generalization and semantic representation capabilities, CTI-Thinker performs instruction tuning on a pre-trained large language model (i.e., LLaMA-3-8B). Instead of relying on full-parameter fine-tuning, which demands substantial computational and memory resources, the system adopts Low-Rank Adaptation (LoRA). This approach freezes the original model parameters and updates only a lightweight set of trainable low-rank matrices, thereby significantly reducing training costs while improving adaptability to CTI-specific extraction tasks.

Specifically, LoRA represents the update component ΔW of the original weight matrix $W_0 \in \mathbb{R}^{m \times n}$ as the product of two trainable low-rank matrices $A \in \mathbb{R}^{r \times m}$ and $B \in \mathbb{R}^{n \times r}$, where $r \ll \min(m, n)$. The final weight update can be formulated as follows:

$$W = W_0 + \Delta W = W_0 + BA \quad (3)$$

Our approach enables the model to retain pre-trained knowledge while effectively acquiring domain-specific representations related to CTI, including entity labels, contextual semantics, and structured triple patterns. During the fine-tuning phase, the model is trained on instruction–output pairs derived from annotated CTI corpora, learning to extract standardized knowledge triples from semantically complex threat statements. Each training instance is constructed in the form of a task instruction, an input sentence, and the corresponding triple-level output. The annotated entities cover core CTI elements such as APT groups, malware families, exploitation tools, target industries, and CVE identifiers, along with common semantic relations including *Use*, *Exploit*, *Target_at*, *Located_at*, and *Indicate*.

The fine-tuned LLM is capable of processing prompt templates generated by the in-context learning module, which incorporate the task instruction, semantically relevant examples, and the target query sentence. It then accurately produces structured knowledge units in the form of relational triples, as illustrated in Equation (4):

$$\text{CTI-Thinker}(\text{Prompt}) \rightarrow \langle \text{entity}_i, \text{relation}_{ij}, \text{entity}_j \rangle \quad (4)$$

These extracted triples serve as the fundamental semantic components for constructing cyber threat intelligence (CTI) knowledge graphs, supporting critical downstream applications such as threat attribution analysis, tactic–technique–procedure (TTP) reasoning, and alignment with the MITRE ATT&CK framework.

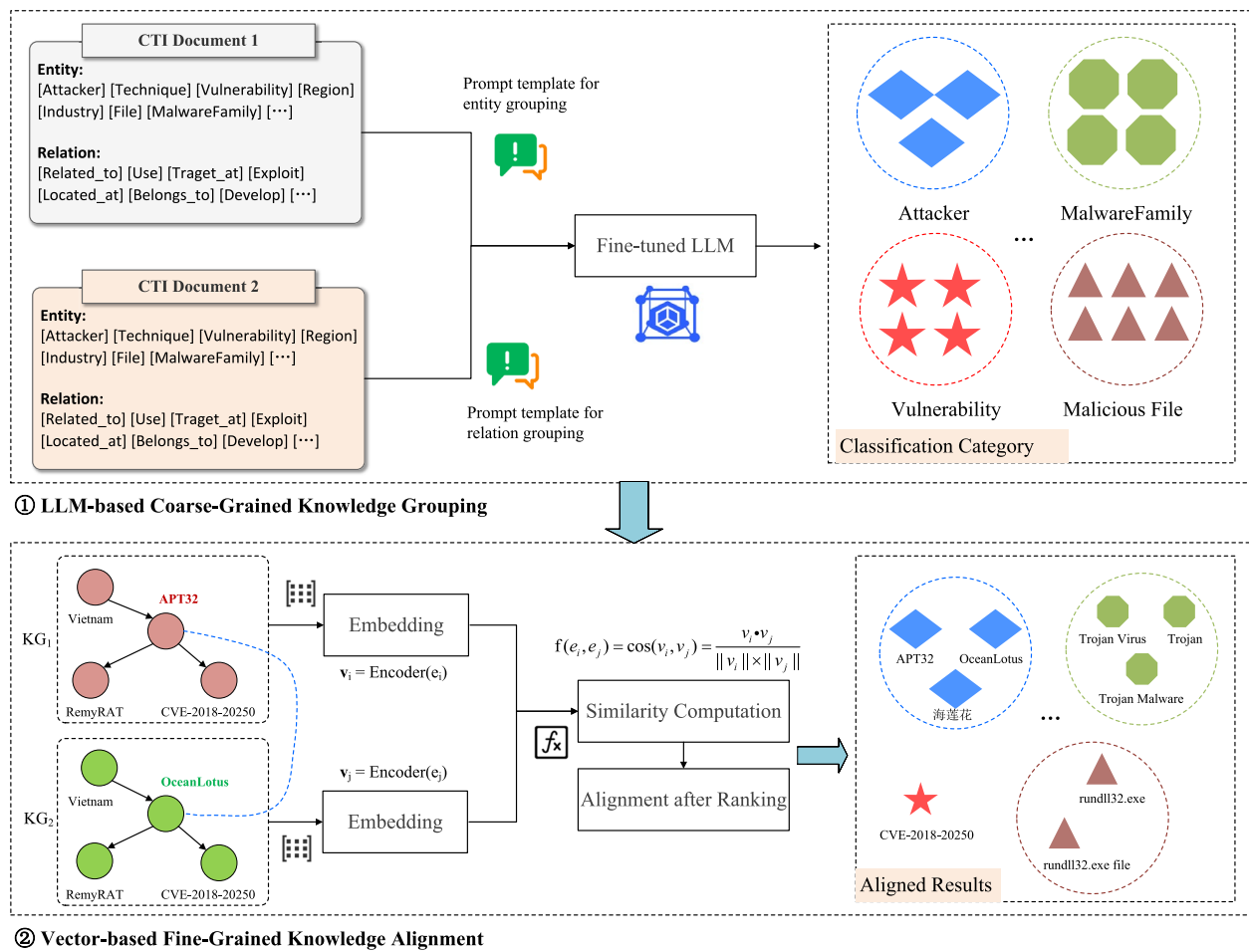


Fig. 5 The architecture for entity and relation alignment

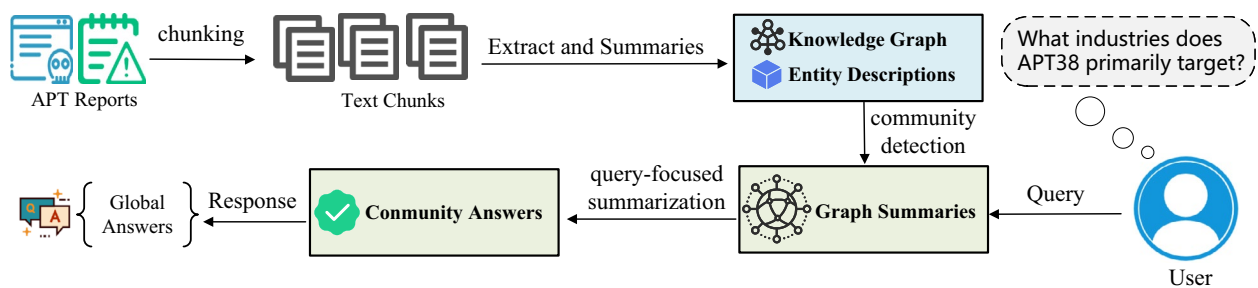


Fig. 6 The architecture for CTI engine based on GraphRAG and ATT&CK

Knowledge alignment leveraging LLM and vector-based similarity analysis

To achieve high-quality integration and normalization of threat intelligence, CTI-Thinker implements a two-stage knowledge alignment framework, consisting of coarse-grained knowledge grouping using LLMs and fine-grained entity alignment via vector-based similarity computation. This hierarchical strategy ensures semantic consistency and structural coherence across

heterogeneous threat entities derived from diverse CTI sources. The overall architecture of this alignment process is illustrated in Fig. 5.

LLM-Based Coarse-Grained Knowledge Grouping. CTI-Thinker extracts structured entities and relations from raw CTI documents, then applies prompt templates to instruct a fine-tuned LLM to infer semantic categories. For instance, “APT32” and “OceanLotus” are classified under the attacker category, while “Trojan Virus”

and “Trojan” are grouped as malicious file. By leveraging instruction tuning and prompt-based alignment, the LLM assigns consistent semantic labels across entities and relations, enabling initial normalization of heterogeneous CTI elements.

Vector-Based Fine-Grained Knowledge Alignment.

On top of coarse grouping, CTI-Thinker introduces a semantic vector alignment mechanism to identify semantically equivalent entities with different surface forms (e.g., “APT32” and “OceanLotus”). The complete procedure is outlined in Algorithm 1.

Each entity e_i and e_j is encoded into a high-dimensional semantic vector using a pre-trained and fine-tuned language model encoder. Cosine similarity is then employed to quantify the semantic closeness between the corresponding entity embeddings. Subsequently, entity alignment is performed by comparing the similarity score against a predefined threshold τ , where $\tau \in [0, 1]$ denotes a validation-tuned similarity cutoff used to determine equivalence between entity pairs. This process enables CTI-Thinker to unify diverse entity mentions such as “Trojan” or “rundll32.exe file” into consistent nodes, facilitating semantic normalization and supporting downstream CTI knowledge graph construction, including threat attribution, TTP inference, and ATT&CK phase mapping.

Algorithm 1 Knowledge alignment based on LLM and semantic vector analysis.

Input: $D = \{d_1, d_2, \dots, d_n\}$, where d_i represents the i -th CTI document. For each document d , let $\mathcal{E}_d$ be the set of extracted entities and $\mathcal{R}_d$ the set of extracted relation triples.

Output: $\mathcal{K}_{\text{aligned}}$: the set of aligned and merged threat knowledge triples.

Step 1: LLM-based Coarse-Grained Grouping

foreach $d \in D$ **do**

foreach $e \in \mathcal{E}_d \parallel r \in \mathcal{R}_d$ **do**

$d_{\text{labeled}} = \text{LLM}_{\text{fine-tuned}}(\text{Prompt}(e, r, d))$;

// the classified or labeled document d .

$D_{\text{labeled}}.\text{append}(d_{\text{labeled}})$

Step 2: Vector-Based Embedding and Storage

Initialize vector database $\mathcal{V} \leftarrow \emptyset$;

foreach $d \in D_{\text{labeled}}$ **do**

foreach $e \in \mathcal{E}_d$ **do**

 Compute entity embedding $\mathbf{v}_e \leftarrow \text{Encoder}(e)$;

 Store tuple $(e, \mathbf{v}_e, c_e)$ into vector database $\mathcal{V}$;

Step 3: Similarity-Based Matching and Merging

foreach category c in all entity categories **do**

$\mathcal{V}_c \leftarrow$ filter entries from $\mathcal{V}$ with category c ;

foreach $(e_i, \mathbf{v}_i) \in \mathcal{V}_c$ **do**

foreach $(e_j, \mathbf{v}_j) \in \mathcal{V}_c$ **and** $j > i$ **do**

 Compute cosine similarity $S \leftarrow \frac{\mathbf{v}_i \cdot \mathbf{v}_j}{\|\mathbf{v}_i\| \times \|\mathbf{v}_j\|}$;

if $S \geq \tau$ **then**

 Merge e_i and e_j as equivalent entities;

Step 4: Output Aligned Threat Knowledge

Construct final structured CTI knowledge graph $\mathcal{K}_{\text{aligned}}$ from merged entities and relations.

CTI reasoning engine based on GraphRAG and ATT&CK semantic mapping

We propose a CTI reasoning engine that integrates the GraphRAG architecture with semantic mapping to the MITRE ATT&CK framework, as shown in Fig. 6. Built upon the RAG paradigm, this reasoning module leverages GraphRAG to support structured knowledge retrieval and tactical behavior mapping across APT attack chains. Consequently, it facilitates automated threat reasoning and intelligent question answering within the context of CTI and APT analysis.

Threat reasoning indexing stage. CTI-Thinker performs fine-grained semantic mapping on raw documents based on structured CTI corpora and external security knowledge sources, including the ATT&CK framework and STIX 2.1 standard. Specifically, each CTI document is segmented into semantically coherent chunks, from which the system extracts security-relevant elements (e.g., semantic entities and TTP behaviors) to construct a structured entity set. For each extracted entity, a corresponding semantic description is generated, forming a set of entity–summary pairs.

Subsequently, the system performs clustering and abstraction based on semantic embeddings and graph topological structures. Entities are grouped according to semantic similarity, where each cluster represents a coherent category of threat elements (e.g., attacker,

vulnerability, equipment). For each cluster, an aggregated semantic summary is generated to form a well-defined knowledge community. These communities are encoded into graph-representable node embeddings and stored in a graph index database to support downstream reasoning, enhancing the model's understanding of domain-specific terms and contextual semantics through fact-grounded representations.

Threat reasoning query stage. CTI-Thinker first encodes the user query into a dense vector representation and projects it into a corresponding knowledge community (e.g., APT attack stage or malware propagation network) via graph-based embedding. Then, GraphRAG identifies the most semantically relevant nodes and their adjacent entities within the graph, and constructs a context-aware subgraph by traversing the neighborhood structure. Unlike traditional RAG which concatenates plain text chunks, GraphRAG utilizes entity descriptions and intra-cluster summaries to generate graph-aware prompts, which are subsequently fed into the LLM for contextual reasoning and natural language generation.

When a user query involves multiple communities (e.g., reasoning over a multi-stage ATT&CK chain), our system adopts a global path fusion and semantic aggregation mechanism to integrate reasoning paths across graph substructures. This ensures logical completeness while aligning the inference output with the TTP nodes defined in the ATT&CK framework, thereby enhancing both the interpretability and semantic adequacy of the results. As illustrated in Fig. 6, GraphRAG effectively identifies the target information of APT38, demonstrating its capability to capture attacker-specific objectives. The overall reasoning process in GraphRAG can be formalized as follows:

$$\text{Answer}(q) = \text{LLM}\left(q, \{d_k\}_{k=1}^K\right), \quad (5)$$

where $d_k \sim \arg \max_{d \in D} \cos(f_{\text{query}}(q), f_{\text{doc}}(d))$

where f_{query} and f_{doc} denote the embedding functions that project the query and document nodes into the semantic vector space, $\cos(\cdot)$ represents the cosine similarity, and D is the pre-constructed vector database. The set $\{d_k\}_{k=1}^K$ denotes the top- K context nodes retrieved to construct the final prompt.

Furthermore, by aligning with the ATT&CK knowledge framework, CTI-Thinker annotates the mapping between attack tactics and techniques within GraphRAG-based inference results, enabling structured attribution from “raw statements” to “tactical identification.” This process also supports the generation of visualized TTP timelines and behavioral pattern descriptions. For example, in response to the query “Attack methods used by APT32 involving RemyRAT”, the system not only retrieves relevant vulnerabilities and tools but also outputs the ATT&CK tactical sequence such as “Remote Access Trojan Implantation → Persistence → Command and Control.” The reasoning module supports both global and local queries, facilitating fine-grained analysis of specific behaviors or malware instances.

Evaluation

In this section, we conduct systematic evaluations to verify the effectiveness, robustness, and reasoning capability of CTI-Thinker. The experiments are designed to address the following research questions:

- *RQ1: Effectiveness of Entity Extraction* How effectively can CTI-Thinker identify diverse threat entities (e.g., malware families, vulnerability, and APT groups) from unstructured CTI reports? We evaluate its performance to determine whether it outperforms state-of-the-art LLM approaches and traditional deep learning-based methods.

Table 3 Experimental results for the CTI entity recognition task

Model	Precision	Recall	F ₁ -score
Bert+BiLSTM-CRF	0.7562	0.7221	0.7388
ATTCKG+ (Zhang et al. 2025)	0.6365	0.8531	0.7290
LLM-TIKG (Hu et al. 2024)	0.8580	0.7500	0.8004
ChatGPT-4o	0.6251	0.8412	0.7172
DeepSeek-R1	0.7651	0.7071	0.7349
lora-LLama3-8B	0.8709	0.6834	0.7658
lora-QWen	0.7853	0.2637	0.3948
lora-Mistral-7B	0.7978	0.7162	0.7548
CTI-Thinker (Ours Method)	0.8314	0.8458	0.8385

The bold values indicate the results obtained by the proposed method in this paper

Table 2 CTI knowledge graph construction experimental datasets

Dataset	Number of sentences			Number of entities			Number of relations		
	Train	Val	Test	Train	Val	Test	Train	Val	Test
CTI-Thinker	2762	345	345	6786	816	827	3957	477	509
LLM-TIKG	1410	176	176	5514	681	672	2955	374	385

- *RQ2: Effectiveness of Relation Extraction* Can CTI-Thinker accurately extract semantic relations among identified entities under complex and long-form contexts?
- *Q3: Effectiveness of In-Context Learning* Can in-context learning combined with the KNN retrieval algorithm truly enhance the performance of CTI knowledge extraction? How effectively can CTI-Thinker generate knowledge graphs for CTI articles?
- *RQ4: Knowledge Alignment Performance* How helpful is knowledge alignment to the construction of the CTI knowledge graph? We focus on evaluating the effectiveness of the proposed multi-granularity alignment mechanism in normalizing heterogeneous threat concepts and facilitating high-quality knowledge fusion.
- *RQ5: Threat Reasoning in Real-world CTI Scenarios* How effectively can CTI-Thinker perform deep reasoning over knowledge graphs augmented by ATT&CK to support tactical-level question answering and attack chain inference? We test its GraphRAG-based engine in multi-turn reasoning settings involving real-world CTI case studies.

Datasets and evaluation metrics

To comprehensively evaluate the performance of CTI-Thinker in CTI entity recognition, relation extraction, and attack reasoning tasks, we construct and utilize a high-quality CTI dataset. The data sources include APT analysis reports released by leading cybersecurity vendors such as FireEye, McAfee, Kaspersky, Mitre, and Qihoo 360, as well as open-source CTI repositories. The final dataset comprises a representative collection of entities, including APT groups, attack tools, and vulnerability, along with their hierarchical relations. The detailed statistics are presented in Table 2. The dataset is split into training, validation, and test sets in an 8:1:1 ratio. Among them, the CTI-Thinker dataset is newly curated and open-sourced in this study, while LLM-TIKG (Hu et al. 2024) is a publicly available dataset characterized by diverse writing styles, document structures, and the complexity of real-world contextual scenarios.

For evaluation metrics, this study adopts three widely used indicators in the fields of entity recognition and relation extraction: Precision, Recall, and F1-score. To mitigate randomness, all experimental results are averaged over ten independent runs. In terms of baseline configurations, two representative deep learning models (i.e., BiLSTM-CRF and BERT-BiLSTM-CRF) are selected as traditional baselines. Additionally, five representative fine-tuned large language models are included, namely

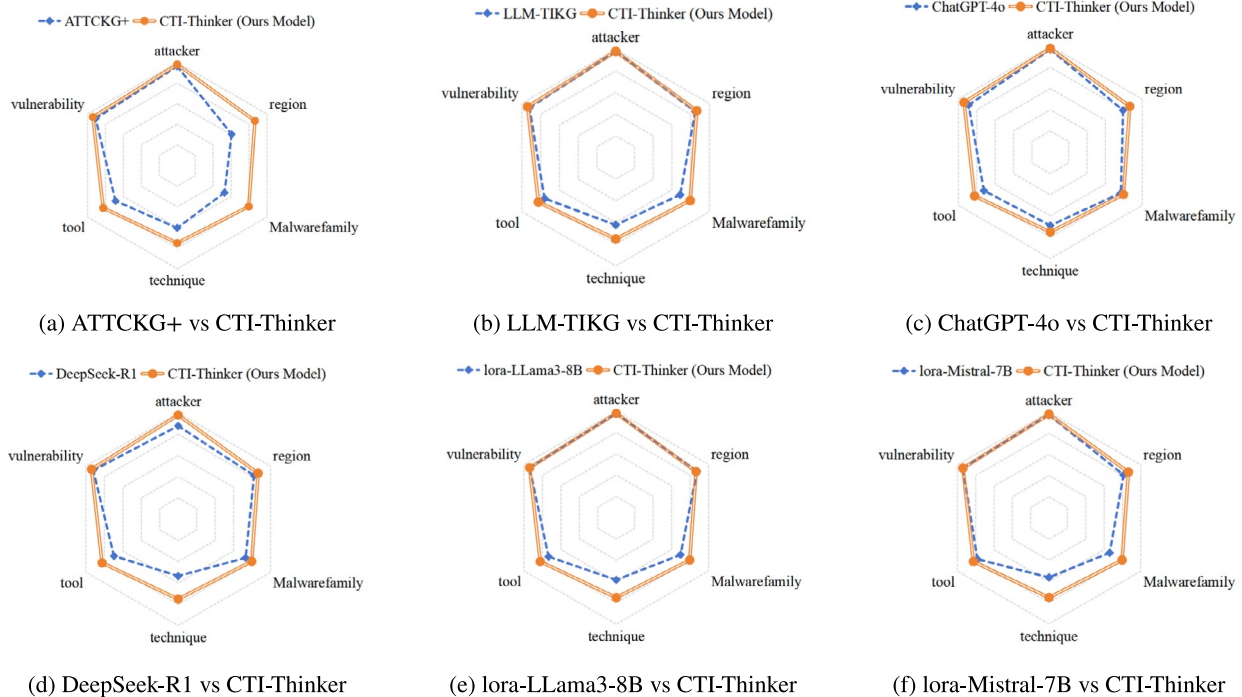


Fig. 7 Comparison of F_1 -score across six representative entity types for different models

Table 4 Experimental results for the CTI relation recognition task

Model	Precision	Recall	F_1 -score
Bert+BiLSTM-CRF	0.5662	0.5108	0.5371
ATTCKG+ (Zhang et al. 2025)	0.4384	0.7610	0.5563
LLM-TIKG (Hu et al. 2024)	0.6703	0.6682	0.6693
ChatGPT-4o	0.6087	0.6087	0.5902
DeepSeek-R1	0.6397	0.5723	0.6041
lora-LLama3-8B	0.7670	0.4969	0.6031
lora-QWen	0.7009	0.2579	0.3770
lora-Mistral-7B	0.6779	0.4764	0.5596
CTI-Thinker (Ours Method)	0.7769	0.7610	0.7689

The bold values indicate the results obtained by the proposed method in this paper

GPT-4o, DeepSeek-R1, LoRA-LLama3-8B, LoRA-QWen, and LoRA-Mistral-7B. To further assess performance in practical CTI scenarios, two state-of-the-art knowledge extraction systems, AttackG+ (Zhang et al. 2025) and LLM-TIKG (Hu et al. 2024), are incorporated for comparison. All models are evaluated on the same dataset under a unified evaluation framework and server environment to ensure fairness and comparability. This comprehensive setup enables a robust assessment of CTI Thinker's effectiveness in CTI extraction tasks.

Experimental setup

In this experiment, we perform parameter-efficient fine-tuning of the LLaMA3-8B model using the LoRA technique within the LLaMA-Factory framework for the cyber threat intelligence extraction task. Training is conducted on an NVIDIA A40 GPU with 48 GB of memory. We adopt a retrieval-augmented prompt construction strategy, where each test input is concatenated with the

Table 5 Comparative experiments on KNN retrieval under different top-k values and numbers of randomly selected examples

Type	K-values	Triple F_1 -score	Entity F_1 -score
Randomly selected examples	0-Example	0.6513	0.8086
	1-Example	0.6310	0.7992
	3-Examples	0.6949	0.8117
	5-Examples	0.6799	0.8052
Samples used in ICL-based KNN retrieval	1-Example KNN	0.7081	0.8262
	3-Examples KNN	0.7349	0.8288
	5-Examples KNN	0.7434	0.8229
	7-Examples KNN	0.7689	0.8385
	9-Examples KNN	0.7599	0.8528

The bold values indicate the results obtained by the proposed method in this paper

top-k semantically similar examples to enhance contextual understanding.

LoRA modules are inserted into the key sub-layers of the attention mechanism and feedforward networks, enabling efficient adaptation without modifying the original model parameters. The input sequence length is set to a maximum of 1024 tokens, with a learning rate of $2e-5$ and a cosine learning rate scheduling strategy. The model is trained for 10 epochs with a gradient accumulation step size of 8. Validation is performed every 50 steps, and checkpoints are saved every 100 steps. Mixed precision (FP16) training is employed to reduce memory consumption.

Analysis of entity and relation extraction (RQ1 and RQ2)

We conduct a comprehensive comparison of CTI entity recognition performance across representative methods, as summarized in Table 3. CTI-Thinker consistently demonstrates superior performance across all three key metrics, achieving a precision of 0.8314, recall of 0.8458, and an F_1 -score of 0.8385, thereby outperforming all baseline models. Compared with the traditional deep learning model Bert+BiLSTM-CRF, CTI-Thinker achieves a 9.97% improvement in F_1 -score. It also surpasses the knowledge-enhanced models ATTCKG+ and LLM-TIKG by 10.95% and 3.81%, respectively.

Moreover, CTI-Thinker outperforms leading proprietary large models such as ChatGPT-4o and DeepSeek-R1 in terms of F_1 -score. When compared with state-of-the-art open-source LLMs, including lora-LLama3-8B, lora-QWen, and lora-Mistral-7B, our method maintains a consistent advantage. These results collectively demonstrate that CTI-Thinker offers a more robust and comprehensive entity recognition capability, underscoring its effectiveness in cyber threat intelligence (CTI) knowledge extraction. Furthermore, the integration of in-context learning with a LoRA-based fine-tuning strategy significantly enhances the model's stability and generalization across diverse scenarios.

Table 6 Experimental results of in-context learning based on different vectorization methods

Model	Triple F_1 -score	Entity F_1 -score
Ours Method (TFIDF+Similarity computation)	0.7689	0.8385
all-MiniLM-L6-v2	0.7488	0.8144
all-mpnet-base-v2	0.7563	0.8155
SecureBERT	0.7587	0.8274

The bold values indicate the results obtained by the proposed method in this paper

To further evaluate the ability of different models to recognize entity types in the CTI extraction task, we select six representative entity categories (i.e., attacker, malware family, region, technique, tool, and vulnerability) from the dataset and visualize the results using the radar chart shown in Fig. 7. The chart compares the F_1 -scores of CTI-Thinker (orange solid lines) and representative baseline models (blue dashed lines) across all entity types. As shown in the figure, CTI-Thinker consistently outperforms all baseline models across the six

categories, with an outward-expanding radar curve indicating higher recognition accuracy and more balanced performance.

Notably, CTI-Thinker achieves significantly higher F_1 -scores in several challenging entity categories, such as malware family (0.7959), technique (0.7516), and tool (0.8241). For example, in the technique category, CTI-Thinker achieves an F_1 -score of 0.7516, clearly outperforming LLM-TIKG (0.6222) and lora-Mistral-7B (0.5607). Even in categories where traditional models typically perform well, such as attacker and vulnerability, CTI-Thinker maintains either a leading or competitive level of performance, with respective scores of 0.9797 and 0.9388.

We further evaluate the performance of each model on the CTI relation extraction task. As relation extraction is inherently more complex than entity recognition, the overall performance tends to be lower than that reported in Table 3. As shown in Table 4, CTI-Thinker continues to achieve the best performance among all models, with a precision of 0.7769, a recall of 0.7610, and an F_1 -score of 0.7689, outperforming all baselines across all evaluation

Table 7 Experimental results of knowledge extraction based on different open-source foundation models

Model	Triple F_1 -score	Entity F_1 -score
LLama3-8B (Ours Method)	0.7689	0.8385
QWen3-8B	0.4511	0.4964
Mistral-7B	0.7463	0.8228

The bold values indicate the results obtained by the proposed method in this paper

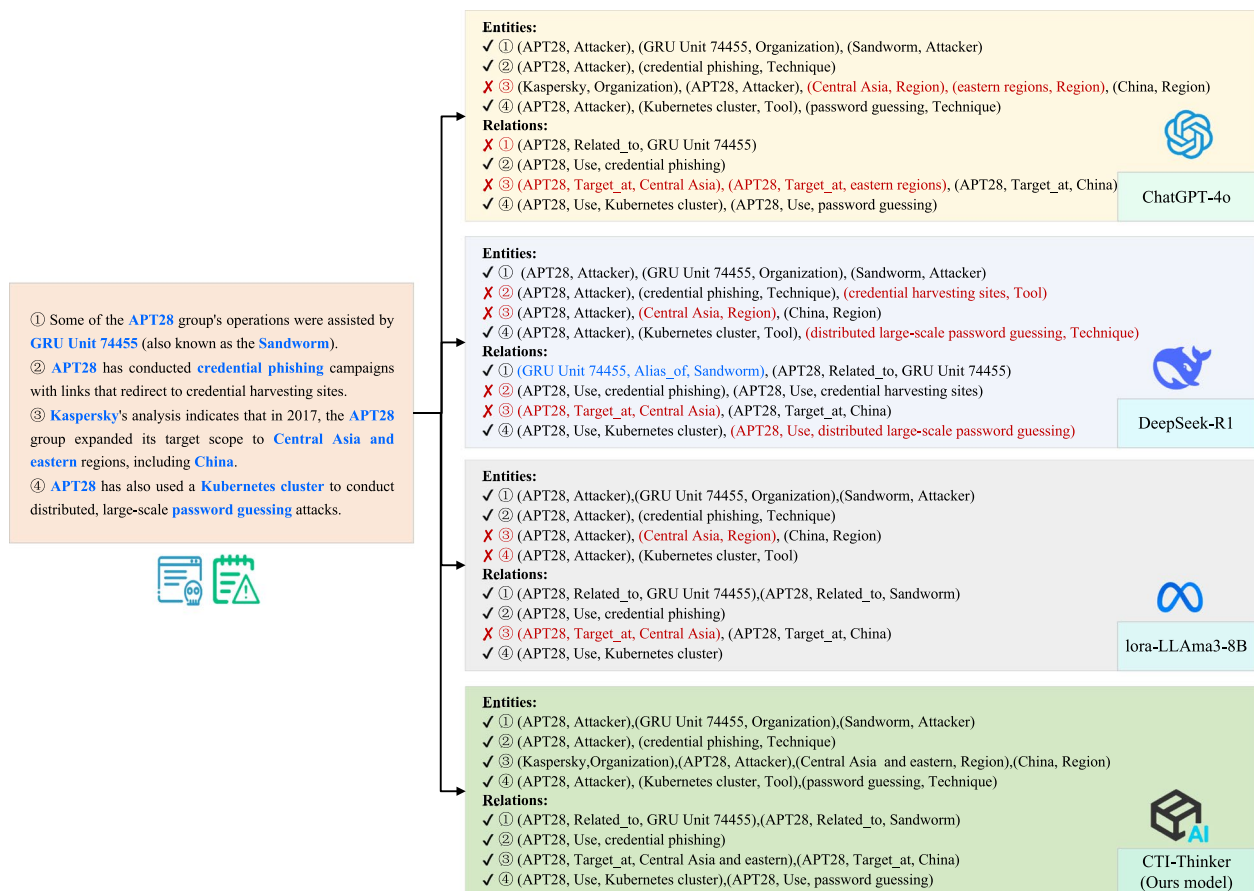


Fig. 8 Comparative results of threat intelligence knowledge extraction examples for the APT28 group

metrics. Compared with ATTCKG+ and LLM-TIKG, which achieve F_1 -scores of 0.5563 and 0.6693 respectively, CTI-Thinker achieves improvements of approximately 21.26% and 9.96%. In addition, CTI-Thinker outperforms representative proprietary, open-source, and fine-tuned models in relation extraction performance.

In summary, these experimental results demonstrate that CTI-Thinker exhibits superior robustness and generalization in recognizing various types of cyber threat entities and relations. We validate its overall advantage in complex security-oriented semantic understanding and knowledge extraction.

ICL-based knowledge extraction (RQ3)

To further evaluate the effectiveness of in-context learning (ICL) and KNN-based example retrieval for CTI knowledge extraction, we conduct comparative experiments under three example selection strategies: (1) no-example input, (2) randomly selecting a fixed number of examples, and (3) retrieving the top- k most similar examples using a KNN-based retriever.

The experimental results are summarized in Table 5. Among all configurations, the use of KNN-based retrieval with seven examples achieves the best overall performance, yielding an F_1 -score of 0.7689 for triple extraction and 0.8385 for entity recognition. In comparison to random selection, the KNN-based strategy consistently improves performance across all k values,

demonstrating the effectiveness of leveraging embedding similarity to guide example selection. Notably, the zero-example input achieves better performance (0.6513) than randomly selecting one example (0.6310), suggesting that poorly chosen demonstrations may negatively impact model effectiveness. These findings confirm that both the inclusion of contextual examples and the quality of their selection are critical for improving few-shot CTI extraction performance. In summary, models equipped with KNN-based retrieval and in-context learning demonstrate enhanced accuracy in extracting threat entities and relations. However, increasing k is not monotonically beneficial: performance peaks at $k=7$ and slightly declines at larger k , likely due to prompt-length constraints and the inclusion of lower-similarity or conflicting demonstrations; this motivates an adaptive choice of k (e.g., thresholding on the k -th neighbor's similarity) and diversity-aware re-ranking to balance relevance and coverage.

To assess the impact of different vectorization methods on the performance of in-context learning, we conduct comparative experiments based on multiple widely adopted sentence embedding models. As shown in Table 6, we compare our proposed method, which employs TFIDF-based feature extraction combined with similarity computation, with three representative vector encoders: all-MiniLM-L6-v2, all-mpnet-base-v2, and SecureBERT. The results demonstrate that our method

Table 8 Experimental results of CTI entity and relation alignment tasks

Model	Triple alignment			Entity alignment		
	Precision	Recall	F_1 -score	Precision	Recall	F_1 -score
Ours Method (SecureBERT + Embedding Similarity)	0.7354	0.7343	0.7349	0.8385	0.8193	0.8288
ECBERT	0.6833	0.7123	0.6975	0.7947	0.7911	0.7929
CTI-BERT	0.6289	0.6653	0.6458	0.7646	0.7522	0.7522
ATTACK-BERT	0.6822	0.6918	0.6870	0.7603	0.7929	0.7762

The bold values indicate the results obtained by the proposed method in this paper

Table 9 Experimental results of CTI entity and relation alignment tasks

Model	Triple alignment			Entity alignment		
	Precision	Recall	F_1 -score	Precision	Recall	F_1 -score
Unaligned	0.6383	0.6494	0.6438	0.7362	0.7692	0.7523
0.95	0.7352	0.7421	0.7387	0.7868	0.8184	0.8023
0.90	0.7679	0.7594	0.7636	0.8183	0.8385	0.8283
0.85	0.7764	0.7642	0.7702	0.8292	0.8458	0.8374
0.80	0.7780	0.7657	0.7718	0.8301	0.8467	0.8383

The bold values indicate the results obtained by the proposed method in this paper

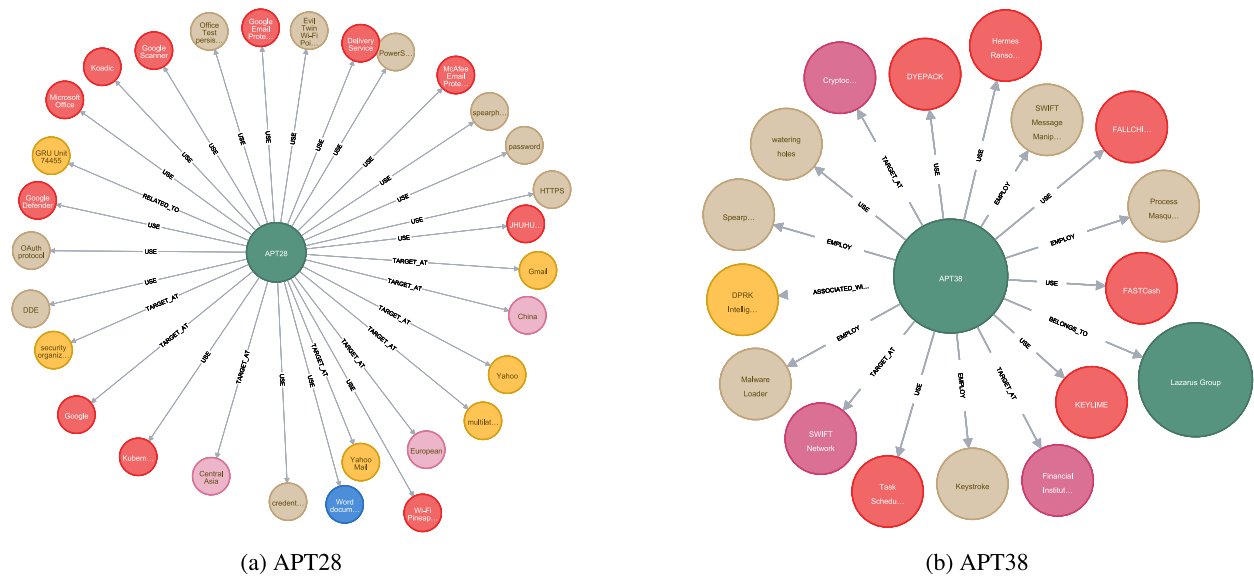


Fig. 9 Representative APT entities and their associated relations in the CTI knowledge graph

Table 10 Example results of knowledge alignment

Type	Aligned entities and relations
Attacker	<(The Dark Caracal group, Attacker), (Dark Caracal, Attacker)> <(Turla team, Attacker), (Turla, Attacker)> <(Fancy Bear, Attacker), (APT28, Attacker)> <(OceanLotus, Attacker), (APT32, Attacker)>
Organization	<(Ministry of Intelligence and Security, Organization), (MOIS, Organization)> <(think tanks, Organization), (U.S. think tanks, Organization)> <(QiAnXin Threat Intelligence Center, Organization), (QiAnXin, Organization)>
Technique	<(DNS protocol, Technique), (DNS, Technique)> <(SMS phishing, Technique), (phishing, Technique)> <(credential capture, Technique), (credential capturing, Technique)> <(malicious email attachments, Technique), (malicious e-mail attachments, Technique)> <(phishing emails, Technique), (phishing, Technique)>
Industry	<(Energy, Industry), (Electric Power, Industry)>
Region	<(United States, Region), (U.S., Region)>
File	<(VBS script, File), (VBS, File)>
Tool	<(netstat -anp, Tool), (netstat, Tool)> <(cmd.exe, Tool), (cmd, Tool)>

Table 11 Quantitative evaluation of threat reasoning across 30 queries covering 20 APT organizations

Model	Accuracy
CTI-Thinker	0.635
LLM-RAG	0.615
Native LLM	0.223

The bold values indicate the results obtained by the proposed method in this paper

achieves the best overall performance, with an F_1 -score of 0.7689 for triplet relation extraction and 0.8385 for entity recognition. Compared to SecureBERT, our method improves triplet-level performance by 1.32% and entity-level performance by 1.11%. These findings indicate that lightweight lexical statistical representations combined with targeted similarity computation are well-suited for guiding example selection in the ICL framework, particularly in CTI knowledge extraction tasks.

To evaluate the adaptability and robustness of CTI-Thinker across different backbone model configurations, we conduct comparative experiments using various open-source foundation models. Specifically, we implement our method based on LLaMA3-8B, QWen3-8B, and Mistral-7B. As shown in Table 7, the CTI-Thinker model built upon LLaMA3-8B achieves the best performance in both triplet relation extraction and entity recognition tasks, with F_1 -scores significantly surpassing those of the competing models. These results demonstrate the strong generalization capability of the proposed approach across different model architectures.

In addition, we conduct a case study using a real-world cyber threat intelligence document involving the APT28 threat actor to visually compare the entity and relation extraction capabilities of four models. As illustrated in Fig. 8, CTI-Thinker successfully extracts complete and accurate entity-relation chains across all four key points,

demonstrating high coverage and precision. In contrast, ChatGPT-4o exhibits errors in region entity recognition by incorrectly segmenting “Central Asia and eastern regions” into multiple disjoint region entities, and its relation extraction results also include mismatches. DeepSeek-R1 misclassifies several entities, such as regions, tools, and techniques, and fails to identify critical organization entities like Kaspersky, which compromises the completeness of its extracted relations. While lora-LLama3-8B is able to capture some elements, it shows limitations in recognizing entity aliases and fine-grained types, such as missing organization and tool entities in the extraction process.

In summary, CTI-Thinker consistently demonstrates superior performance in both quantitative evaluation and real-world case analysis, exhibiting enhanced capabilities in entity recognition and relation extraction. These advantages stem from the effectiveness of its in-context



What industries does APT38 primarily target?



CTI-Thinker:

According to the reports, APT38 primarily targets the **financial industry**, including SWIFT transactions, banking institutions, and cryptocurrency platforms, and extends its operations to the **telecommunications, government, defense, and critical infrastructure** sectors, aiming to exploit high-value digital assets and operational systems.

[Data: Reports (3), Entities (9); Relationships (35)]

Strong comprehension, precise answers, and evidence-based justification



LLM (no RAG):

APT38, also known as Lazarus Group or Hidden Cobra, is a notorious North Korean state-sponsored hacking group. According to various reports and threat intelligence sources, APT38 has been involved in targeted attacks against several industries, including:

- Financial sector:** Banks, financial institutions, and cryptocurrency exchanges have been primary targets of APT38's attacks. The goal is often to steal sensitive financial information, such as customer data, account credentials, or transaction records.
 - Healthcare:** Medical facilities, research organizations, and pharmaceutical companies have also been targeted by APT38. The aim may be to obtain intellectual property, patient data, or sensitive medical research information.
 - Aerospace and defense:** Organizations involved in the development of military technology, defense contractors, and government agencies have been hit by APT38's attacks. This could be part of a broader effort to disrupt critical infrastructure and compromise national security.
 - Technology and manufacturing:** Companies involved in the development and production of advanced technologies, such as computer hardware, software, or electronics, have also been targeted. This may include firms working on projects related to artificial intelligence, autonomous systems, or cybersecurity.
 - Government agencies:** APT38 has been known to target government agencies, including those responsible for national security, foreign affairs, and economic development.
- Please note that these industries are not exhaustive, as APT38's attack surface is likely broader than what we currently know. It's essential to remain vigilant and continuously monitor threat intelligence sources to stay ahead of this sophisticated and persistent threat actor.

Redundant responses, weak evidential basis, and overly broad descriptions



RAG:

APT38 is a cybercrime group, also known as the "Lazarus Group", that is primarily known for its involvement in various types of cyberattacks, including:

- Banking Trojans:** APT38 is responsible for the development and distribution of the Dtrack malware, which is a banking Trojan that targets financial institutions and steals sensitive information.
- Ransomware:** The group has been linked to several ransomware attacks, including the WannaCry and NotPetya attacks, which caused widespread disruption and financial losses.
- Cryptocurrency theft:** APT38 has been involved in several high-profile cryptocurrency thefts, including the theft of over \$100 million in cryptocurrency from the cryptocurrency exchange Coincheck.
- Cyber espionage:** The group has also been involved in cyber espionage activities, targeting government agencies, defense contractors, and other organizations in the defense and aerospace industries.
- Phishing:** APT38 has been known to use phishing emails to trick victims into revealing sensitive information or installing malware on their devices.

In terms of specific industries, APT38 has targeted:

- Financial institutions:** Banks, credit unions, and other financial institutions have been targeted by APT38's banking Trojans and ransomware attacks.
 - Technology and software companies:** The group has targeted companies in the technology and software industries, including those involved in the development of cryptocurrency and blockchain technology.
 - Government agencies:** APT38 has been involved in cyber espionage activities targeting government agencies, including those involved in defense and national security.
 - Healthcare:** The group has targeted healthcare organizations, including hospitals and medical research institutions.
 - Aerospace and defense:** APT38 has targeted companies involved in the aerospace and defense industries, including those involved in the development of military technology.
- It's worth noting that APT38's targets are not limited to these industries, and the group has been known to target organizations in a wide range of sectors.

Off-topic response with insufficient justification and verbose exposition

Fig. 10 Comparative analysis of APT group target attribution and question answering results

learning strategy and KNN-based retrieval mechanism. The experimental results presented in this section validate the practical value and effectiveness of the proposed method in constructing high-quality knowledge graphs for cyber threat intelligence applications.

Knowledge alignment with CTI-Thinker (RQ4)

This paper proposes a novel two-stage knowledge alignment strategy that combines a fine-tuned LLM with vector-based similarity computation to achieve high-quality normalization of CTI. This framework enables the effective unification of heterogeneous entities and relations from multiple sources, thereby facilitating the construction of consistent and semantically coherent threat knowledge graphs.

To evaluate the performance of the proposed method, we conduct comparative experiments against three representative models: ECBERT, CTI-BERT, and ATTACK-BERT. As shown in Table 8, our method achieves an F_1 -score of 0.7349 for triple alignment and 0.8288 for entity alignment, outperforming all comparison models. Specifically, the proposed approach achieves an average improvement of approximately 5.81% in triple alignment and 5.50% in entity alignment over the three baseline methods. These results demonstrate its superior performance in integrating heterogeneous CTI knowledge.

Overall, these findings confirm the advantages of our hierarchical alignment framework in promoting semantic consistency and cross-text integration. By leveraging the representational strength of SecureBERT and embedding-based similarity computation, the method significantly enhances the robustness and utility of CTI alignment, laying a solid foundation for constructing high-quality CTI knowledge graphs.

Table 9 presents the performance of entity and relation alignment tasks at different similarity thresholds, ranging from 0.80 to 0.95. The results indicate that a threshold of 0.80 provides the best overall performance, achieving the highest F_1 -scores for both triple alignment (0.7718) and entity alignment (0.8383). At this threshold, the model captures a wider range of valid alignments, improving recall without sacrificing precision. We tested lower thresholds and found that 0.80 provides the best performance. Although thresholds below 0.80 showed a slight improvement in recall, further inspection revealed that entity alignment at these lower thresholds had little effect and was prone to overfitting the dataset. This overfitting leads to capturing unnecessary matches, which harms the model's ability to generalize. Therefore, we concluded that further lowering the threshold does not provide meaningful improvements.

Table 10 presents knowledge alignment examples across multiple entity and relation categories. The alignment results demonstrate that CTI-Thinker effectively identifies synonymous expressions, linguistic variants, and abbreviation mappings. For instance, in the Attacker category, entities such as “Fancy Bear” and “APT28,” as well as “OceanLotus” and “APT32,” are correctly aligned, enhancing the normalization of heterogeneous named entities. In the Organization category, the method accurately aligns “MOIS” with its full form “Ministry of Intelligence and Security.” In the Technique category, it is also capable of handling phrasal variations, aligning terms like “SMS phishing” and “phishing.” These results confirm that the proposed two-stage alignment framework in CTI-Thinker exhibits strong capabilities in standardizing entities and relations from multi-source heterogeneous CTI texts, providing a solid foundation for constructing semantically consistent threat knowledge graphs. Figure 9 further visualizes representative APT entities and their associated relations within the constructed knowledge graph.

Threat reasoning analysis in CTI Contexts (RQ5)

In this study, CTI-Thinker leverages a GraphRAG-based framework and semantic alignment with the ATT&CK knowledge base to enable intelligent question answering and TTP-level reasoning for cyber threat intelligence. We construct the experiment with the three models listed in Table 11 (CTI-Thinker, LLM-RAG, and a native LLM), and pose 30 queries covering 20 APT organizations (targets, regions, tools, and TTPs). Using exact-match accuracy after ontology/alias normalization as the metric, the averaged accuracies are 0.635, 0.615, and 0.223, respectively, providing a concise quantitative comparison of effectiveness and generalization. Through comprehensive comparative experiments, we validate the system's capability in understanding complex semantics and its advantage in ATT&CK-aligned knowledge representation. The results demonstrate that CTI-Thinker provides enhanced accuracy and interpretability in tasks such as target attribution, malicious tool analysis, and tactic–technique inference for threat actor profiling.

Figure 10 illustrates the performance of CTI-Thinker in the target attribution task for APT38. Leveraging the GraphRAG framework, the system accurately identifies the financial sector as APT38's primary target by reasoning along the “APT group – target” relational path, while also revealing additional high-value sectors (e.g., telecommunications, government, and defense). Compared to conventional RAG and standalone LLM models, GraphRAG significantly reduces analytical overgeneralization and contextual mismatches by performing structured retrieval over the knowledge graph and enforcing



What TTPs or malware has APT38 used in their campaigns?



CTI-Thinker:

Based on the CTI reports, APT38 has employed a range of malicious techniques, tactics, and malware in their campaigns. Here are some key findings:

1. Malware

- (1) **Hermes Ransomware**: APT38 has been known to use Hermes Ransomware, which employs AES256 encryption to encrypt files.
- (2) **DYEPACK**: A malicious implant used to manipulate SWIFT messages, enabling financial fraud by altering transaction records en route to printers.
- (3) **KEYLIME**: A keylogging tool used to capture keystrokes and exfiltrate sensitive data from victim machines.
- (4) **KillDisk**: A destructive tool designed to wipe hard drive data and corrupt master boot records (MBR), often used to cover attack traces and disable recovery.
- (5) **Mimikatz**: Deployed to extract credentials from memory, facilitating privilege escalation and lateral movement across compromised networks.

2. Core Techniques (with MITRE ATT&CK IDs)

- (1) **Command and Scripting Interpreter (T1059)**: Executes malicious commands via PowerShell, cmd.exe, or scripts embedded in HTML or DLL loaders.
- (2) **Impair Defenses (T1562)**: Disables logging, antivirus software, or system firewalls to evade detection.
- (3) **Phishing (T1566)**: Sends spear-phishing emails with malicious attachments or links as initial access vectors.
- (4) **Process Injection (T1055)**: Injects malicious payloads into legitimate system processes (e.g., explorer.exe) to remain stealthy.
- (5) **Obfuscated Files or Information (T1027)**: Applies packing, encryption, or encoding schemes to evade static analysis and signature-based detection.
- (6) **Prohibited Behavior Obfuscation (T1070)**: Alters file timestamps and clears logs to hide malicious activity.
- (7) **Data Manipulation (T1565)**: Tampered SWIFT transaction records during intrusions targeting banks and financial institutions.
- (8) **Application Layer Protocol (T1071)**: Establishes command-and-control (C2) communication over HTTP/S channels, blending with normal network traffic.

These findings highlight APT38 as a highly sophisticated and persistent threat actor with an expansive toolset tailored for financial disruption and covert operations. Their combination of ransomware, credential theft, data manipulation, and anti-forensics emphasizes the need for multilayered defense and behavioral detection techniques to mitigate advanced threats.

Accurate TTP and malware mapping to ATT&CK with sufficient evidence and deep reasoning



LLM (no RAG):

APT38, also known as Lazarus Group or Hidden Cobra, is a notorious North Korean state-sponsored hacking group known for its sophisticated tactics, techniques, and procedures (TTPs). Over the years, they have employed various tools and malware to carry out their attacks. Here are some of the most notable ones:

1. **Dtrack**: A custom-built remote access tool (RAT) used to gain persistence and control over compromised systems.
2. **Fallchill**: A Python-based backdoor used for data theft, command execution, and file manipulation.
3. **Androoks**: A custom-built Android malware used for espionage and surveillance purposes.
4. **HazardousNightingale**: A malware family used to target Windows systems, which includes tools like the "HazardousNightingale" dropper, "Astaroth" backdoor, and "Hive" command-and-control (C2) server.
5. **Saxony**: A Python-based malware used for data exfiltration, file encryption, and system compromise.
6. **Volgmer**: A Windows-based malware family used for espionage, data theft, and system compromise.
7. **AgentBee**: A Linux-based malware used for espionage and surveillance purposes.
9. **Spearphishing emails**: APT38 often uses spearphishing emails with malicious attachments or links to deliver malware and compromise targets.

These tools are just a few examples of the malware families and tactics employed by APT38. The group is known for its adaptability, constantly updating their arsenal with new tools and techniques to evade detection and achieve their goals. It's essential to stay informed about APT38's TTPs and the tools they use to protect yourself and your organization from these sophisticated threats.

Lacks TTPs, hallucinatory response, lacks supporting evidence, overly general description



RAG:

APT38, also known as the Lazarus Group, has used a variety of tools and malware in their campaigns. Some of the notable ones include:

1. **Dtrack**: A banking Trojan that targets financial institutions and steals sensitive information such as login credentials, credit card numbers, and other financial data.
2. **Andariel**: A remote access Trojan (RAT) that allows attackers to remotely control infected devices and steal sensitive information.
3. **WildCore**: A malware family that includes a variety of tools, including a keylogger, a screen scraper, and a file stealer.
4. **Wannacry**: A ransomware variant that was used in a global cyberattack in 2017, which infected over 200,000 computers in over 150 countries.
5. **NotPetya**: A ransomware variant that was used in a cyberattack in 2017, which targeted companies in the Ukraine and globally, causing widespread disruption and financial losses.
6. **BadRabbit**: A ransomware variant that was used in a cyberattack in 2017, which targeted companies in the Ukraine and globally, causing widespread disruption and financial losses.
7. **Destover**: A malware family that includes a variety of tools, including a keylogger, a screen scraper, and a file stealer.
8. **Agent Tesla**: A keylogger and remote access Trojan (RAT) that allows attackers to remotely control infected devices and steal sensitive information.

These are just a few examples of the tools and malware that APT38 has used in their campaigns. The group is known for its ability to develop and use a wide range of malware and tools to achieve their goals. APT38 has also been known to use various techniques to spread their malware, including:

- * Phishing emails and messages
- * Drive-by downloads
- * Exploiting vulnerabilities in software and operating systems
- * Using infected software updates and patches
- * Using compromised websites and web servers
- * Using compromised networks and infrastructure

The group is highly sophisticated and adaptable, and their tactics and techniques are constantly evolving to evade detection and stay ahead of security measures.

Incorrect TTPs, hallucinated content, lacks supporting evidence, overly general description

Fig. 11 A comparative study of APT38's TTPs and Malware analysis and the corresponding question answering results

precise semantic binding of entities. This leads to more focused, credible, and verifiable threat intelligence analysis, while enabling the system to provide clear and traceable supporting evidence.

Figure 11 highlights the advantages of GraphRAG in analyzing the attack techniques (TTPs) and malware associated with APT38. The CTI-Thinker system not only successfully identifies APT38-related malware (e.g., Hermes, KEYLIME, and DEYPACK), but also accurately maps them to their corresponding MITRE ATT&CK technique identifiers (e.g., T1059 for Command and Scripting Interpreter, T1566 for Phishing, T1055 for Process Injection), thereby enabling a closed-loop reasoning process across tactics, techniques, and tools. In contrast, LLMs without RAG often suffer from hallucinations and fail to correctly interpret TTP-related queries. Traditional RAG-based methods, while more informative, frequently introduce TTPs confusion due to unstructured document concatenation, resulting in overly broad descriptions that lack evidential grounding and proper alignment with the ATT&CK framework. Overall, GraphRAG ensures factual consistency through entity linking, evidence binding, and contextual constraints, offering high-confidence support for tactical threat analysis.

Discussion

In this section, we discuss some limitations of the current work as well as the future work.

Limitations

Limited generalization in complex attack contexts
Although CTI-Thinker demonstrates strong performance in unstructured threat knowledge extraction, it still faces limitations in generalizing to complex attack contexts characterized by redundant expressions, heterogeneous data sources, and semantic ambiguity in APT reports. The model is prone to semantic drift or the generation of redundant triples, particularly in the absence of a clearly defined attack chain. These issues may lead to incorrect entity aggregation or omission, thereby affecting the completeness of the knowledge graph structure and the accuracy of downstream reasoning.

Challenges in multi-turn reasoning and interpretability
While CTI-Thinker integrates a GraphRAG framework to support attack chain reasoning, its ability to maintain coherent context in multi-turn reasoning scenarios (e.g., causal tracing or tactical transitions) remains unstable. The interpretability and consistency of reasoning paths require further improvement for deployment. Moreover, enhanced integration with real-world threat artifacts (e.g., malware samples and event logs) is necessary to support deeper event-level reasoning and attack behavior attribution.

Future work

Cross-modal threat knowledge extraction. We will further evaluate the applicability and robustness of CTI-Thinker across large-scale, multi-source, and multilingual CTI corpora, assessing its effectiveness in knowledge extraction and reasoning across diverse languages and security incident categories. Additionally, we plan to explore prompt engineering strategies and knowledge modeling mechanisms that integrate multimodal inputs (e.g., malware and log data), aiming to extend CTI-Thinker's capabilities to cross-modal threat intelligence extraction.

Enhancing attack chain interpretability via provenance graph modeling. Subsequent efforts will incorporate provenance graphs and the temporal dependencies of attack chain events to strengthen the logical relationships and sequential constraints among adversarial behaviors. This integration is expected to enhance the semantic coherence and interpretability of reasoning paths, thereby supporting more in-depth causal analysis and attribution of attack activities.

Conclusion

In this paper, we present CTI-Thinker, a novel system that integrates large language models (LLMs) with semantic alignment to the ATT&CK framework for constructing CTI knowledge graphs and enabling threat reasoning. CTI-Thinker leverages in-context learning (ICL) and LoRA-fine-tuned LLMs to extract threat entities and relations from unstructured CTI texts. It further employs a two-stage alignment mechanism combining semantic grouping and vector-based similarity to integrate heterogeneous CTI knowledge into a coherent graph. A GraphRAG-based reasoning engine is also introduced, supporting tactic–technique inference and threat-oriented question answering. Experimental results show that CTI-Thinker outperforms existing methods in both knowledge extraction and alignment tasks, achieving F_1 -scores of 0.8385 for entity recognition and 0.7689 for relation extraction, surpassing deep learning baselines, SOTA systems (e.g., ATTCKG+, LLM-TIKG), open-source large models (e.g., ChatGPT-4o, DeepSeek-R1), and fine-tuned models (e.g., LoRA-LLama3-8B, LoRA-QWen, LoRA-Mistral-7B). In the alignment task, it achieves an average improvement of 5.50% in entity alignment and 5.81% in triplet alignment over baseline models, verifying its effectiveness in integrating heterogeneous entities and multi-source CTI expressions. Notably, CTI-Thinker aligns aliases, abbreviations, and semantic variants of APT groups, significantly enhancing the consistency and standardization of the resulting knowledge graph. Finally, CTI-Thinker supports

Table 12 Example of quantitative evaluation for CTI reasoning models

Model	Score	Reasoning	Answer
CTI-Thinker	0.95	The answer correctly identifies that the Gamaredon Group mainly targets “Ukrainian government and defense-related organizations,” which matches both the question and the attribution described in the MITRE ATT&CK knowledge base. The response is precise and well articulated. Although it does not cite specific malware families or exploitation tools, its content remains aligned with the documented threat behavior in ATT&CK, thus meriting a high score	Gamaredon Group is a threat group that primarily targets individuals involved in the Ukrainian government and organizations related to Ukraine’s defense and military sectors
LLM-RAG	0.50	While the answer mentions the technology industry, Gamaredon Group does not primarily target the technology sector. According to the correct answer, Gamaredon Group mainly targets Ukrainian government, defense, and military sectors, which makes the response inaccurate. Though the mentioned tools and methods are relevant, the answer is not aligned with the focus on government and military sectors. Therefore, a lower score is given	According to Analyst 1, Gamaredon Group primarily targets the technology industry, specifically Microsoft Office and Outlook, as indicated by their use of various tools and techniques to inject malware, steal data, and deliver malicious code
Native LLM	0.20	This answer discusses content unrelated to the actual activities of Gamaredon Group. It describes an investment firm’s focus areas, not a cyber espionage group’s attack targets. Therefore, it does not align with the question requirements, resulting in a low score	Gamaredon Group is a private investment firm that targets various industries, but it appears to have a focus on the following sectors: 1.Technology: Gamaredon Group invests in technology companies, particularly those with a focus on software, cybersecurity, data analytics, and artificial intelligence. 2.Energy: Gamaredon Group has invested in energy companies, including those focused on renewable energy, oil and gas, and energy services. 3.Industrial: The firm has invested in industrial companies, including those in the manufacturing, logistics, and supply chain management sectors. Gamaredon Group’s investment strategy is focused on identifying companies with strong growth potential, innovative products or services, and a competitive edge in their respective markets. The firm’s investment team works closely with portfolio companies to drive growth, improve operations, and create long-term value

intelligent threat-oriented question answering and accurately identifies techniques, tactics, and common attack procedures associated with specific APT groups. In conclusion, CTI-Thinker offers an accurate, robust, and comprehensive solution for constructing high-quality, queryable, and inferable CTI knowledge graphs.

Appendix

This appendix introduces the scoring system used in this study to evaluate cyber threat intelligence reasoning models. To comprehensively assess the models' performance in attack reasoning tasks, we designed three scoring dimensions: accuracy, completeness, and relevance. These are explained as follows:

- **Accuracy.** This metric evaluates whether the information provided in the answer is accurate and consistent with established facts, data, or background knowledge.
- **Completeness.** This metric assesses whether the answer comprehensively covers all relevant aspects of the question, ensuring that no key information is omitted.
- **Relevance.** This metric measures whether the answer directly addresses the question and remains focused on its core content.

Additionally, we have defined detailed scoring criteria to clearly demonstrate how the answers are evaluated.

- **Irrelevant or Incorrect (0 points).** The answer is unrelated to the question or contains serious errors, making it unable to answer the question or completely incorrect.
- **Partially Correct with Confusion (0.5 points).** The answer contains some correct information but also includes inaccuracies or confusion.
- **Completely Accurate and Detailed (1 point).** The answer accurately and clearly addresses the question, lists relevant information in detail, and provides sufficient background explanation.

Table 12 presents the answers from three models: CTI-Thinker, LLM-RAG, and Native LLM, to the question "What industries does Gamaredon Group primarily target?" The focus is on evaluating each model's ability to correctly identify the target industries of the Gamaredon Group. Among them, CTI-Thinker performs the best, as its response accurately reflects the known targets of the Gamaredon Group and aligns closely with trusted sources such as the MITRE ATT&CK framework.

Acknowledgements

This work was supported by the National Science Foundation of China under Grants 62562012, 62172308, 62202118, 72261004; the Guizhou Provincial Basic Research Program (Natural Science) under Grant QKHJC-MS[2025]686; the Major Scientific and Technological Special Project of Guizhou Province under Grant [2024]014; the Guizhou Provincial Key Technology R & D Program under Grant PA[2025]004; the Research Project for Recruited Talents at Guizhou University under Grant GDRJH[2024]15; Scientific and Technological Innovation Talent Team of Guizhou Province for Cybersecurity Protection of Computing Power Network under Grant CXTD[2025]029.

Author contributions

XY: Conceptualization, Methodology, Writing—original draft, Writing review and editing, Visualization. RZ: Investigation, Writing—original draft, Validation. YC: Writing review and editing, Funding acquisition, Conceptualization. GP: Writing review and editing, Funding acquisition, Conceptualization. DY: Visualization, Supervision. CC: Visualization, Supervision. CW: Conceptualization, Writing review and editing. DZ: Conceptualization, Writing review and editing. YZ: Writing review and editing, Methodology. ZY: Investigation, Visualization, Supervision.

Availability of data and materials

Data will be made available on request.

Code availability

The code used in the evaluation study will be made publicly available upon the acceptance of this paper.

Declarations

Competing interests

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Author details

¹State Key Laboratory of Public Big Data (Guizhou Big Data Academy), Guizhou University, Guiyang 550025, People's Republic of China. ²College of Computer Science and Technology, Guizhou University, Guiyang 550025, People's Republic of China. ³School of Cyber Science and Engineering, Wuhan University, Wuhan 430072, People's Republic of China.

Received: 21 July 2025 Accepted: 3 November 2025

Published online: 16 January 2026

References

- Abu-Salih B, Al-Tawil M, Aljarah I, Faris H, Wongthongtham P, Chan KY, Beheshti A (2021) Relational learning analysis of social politics using knowledge graph embedding. *Data Min Knowl Disc* 35:1497–1536
- Achiam J, Adler S, Agarwal S, Ahmad L, Akkaya I, Aleman FL, Almeida D, Alten-schmidt J, Altman S, Anadkat S et al (2023) Gpt-4 technical report. *arXiv preprint arXiv:2303.08774*
- Aghaei E, Niu X, Shadid W, Al-Shaer E (2022) Securebert: a domain-specific language model for cybersecurity. In: *Proceedings of the 2022 international conference on security and privacy in communication systems*. Springer, pp 39–56
- Ainslie S, Thompson D, Maynard S, Ahmad A (2023) Cyber-threat intelligence for security decision-making: a review and research agenda for practice. *Comput Secur* 132:103352
- Alam MT, Bhusal D, Park Y, Rastogi N (2023) Looking beyond iocs: automatically extracting attack patterns from external cti. In: *Proceedings of the 26th international symposium on research in attacks, intrusions and defenses*, pp 92–108
- Alam MT, Bhusal D, Nguyen L, Rastogi N (2024) Ctibench: a benchmark for evaluating llms in cyber threat intelligence. In: *Proceedings of the 38th conference on neural information processing systems (NeurIPS)*
- Arikat DR, Abhinav M, Binu N, Parvathi M, Biju N, Arunima K, Vinod P, KA, RR, Conti M (2024) Intellbot: retrieval augmented llm chatbot for cyber

- threat knowledge delivery. In: Proceedings of the 16th IEEE international conference on computational intelligence and communication networks (CICN). IEEE, pp 644–651
- Arikkat DR, Nicolazzo S, Arazzi M, Nocera A, Conti M et al (2025) Droidttp: mapping android applications with ttp for cyber threat intelligence. arXiv preprint [arXiv:2503.15866](https://arxiv.org/abs/2503.15866)
- Chang Y, Wang X, Wang J, Wu Y, Yang L, Zhu K, Chen H, Yi X, Wang C, Wang Y et al (2024) A survey on evaluation of large language models. *ACM Trans Intell Syst Technol* 15:1–45
- Chen Y, Ding J, Li D, Chen Z (2021) Joint bert model based cybersecurity named entity recognition. In: Proceedings of the 2021 4th International conference on software engineering and information management, pp 236–242
- Chen H, Shen X, Lv Q, Wang J, Ni X, Ye J (2024a) Sac-kg: exploiting large language models as skilled automatic constructors for domain knowledge graphs. arXiv preprint [arXiv:2410.02811](https://arxiv.org/abs/2410.02811)
- Chen Y, Cui M, Wang D, Cao Y, Yang P, Jiang B, Lu Z, Liu B (2024b) A survey of large language models for cyber threat detection. *Comput Secur* 145:104016
- Chen G, Chen P, Wang Q, Li H, Zhou X, Wang X, Yu A, Deng X (2025a) Emge: entities and mentions gradual enhancement with semantics and connection modelling for document-level relation extraction. *Knowl Based Syst* 309:112777
- Chen M, Zhu K, Lu B, Li D, Yuan Q, Zhu Y (2025b) Aecr: automatic attack technique intelligence extraction based on fine-tuned large language model. *Comput Secur* 150:104213
- Cheng Y, Bajaber O, Tsegai SA, Song D, Gao P (2025) Ctinexus: leveraging optimized llm in-context learning for constructing cybersecurity knowledge graphs under data scarcity. In: Proceedings of the 2025 IEEE European symposium on security and privacy
- Du D, Guan X, Liu Y, Jiang B, Liu S, Feng H, Liu J (2024) Mad-llm: a novel approach for alert-based multi-stage attack detection via llm. In: Proceedings of the 2024 IEEE international symposium on parallel and distributed processing with applications (ISPA). IEEE, pp 2046–2053
- Edge D, Trinh H, Cheng N, Bradley J, Chao A, Mody A, Truitt S, Metropolitan D, Ness RO, Larson J (2024) From local to global: a graph rag approach to query-focused summarization. arXiv preprint [arXiv:2404.16130](https://arxiv.org/abs/2404.16130)
- Fang Y, Zhang Y, Huang C (2021) Cybereyes: cybersecurity entity recognition model based on graph convolutional network. *Comput J* 64:1215–1225
- Fayyazi R, Taghdimi R, Yang SJ (2024) Advancing ttp analysis: harnessing the power of large language models with retrieval augmented generation. In: Proceedings of the 2024 annual computer security applications conference workshops (ACSAC Workshops). IEEE, pp 255–261
- Fieblinger R, Alam MT, Rastogi N (2024) Actionable cyber threat intelligence using knowledge graphs and large language models. In: Proceedings of the 2024 IEEE European symposium on security and privacy workshops (EuroS &PW). IEEE, pp 100–111
- Gao P, Shao F, Liu X, Xiao X, Qin Z, Xu F, Mittal P, Kulkarni SR, Song D (2021) Enabling efficient cyber threat hunting with cyber threat intelligence. In: 2021 IEEE 37th international conference on data engineering (ICDE). IEEE, pp 193–204
- Guo Y, Liu Z, Huang C, Liu J, Jing W, Wang Z, Wang Y (2021) Cyberrel: joint entity and relation extraction for cybersecurity concepts. In: Proceedings of the 23rd international conference on information and communications security (ICICS). Springer, pp 447–463
- Guo D, Yang D, Zhang H, Song J, Zhang R, Xu R, Zhu Q, Ma S, Wang P, Bi X et al (2025a) Deepseek-r1: incentivizing reasoning capability in llms via reinforcement learning. arXiv preprint [arXiv:2501.12948](https://arxiv.org/abs/2501.12948)
- Guo W, Xue J, Liu Z, Han W, Hu J (2025b) Malgta: large language model-based guided malware tactical analysis. *J Supercomput* 81(9):1049
- Hogan A, Blomqvist E, Cochez M, d'Amato C, Melo GD, Gutierrez C, Kirrane S, Gayo JEL, Navigli R, Neumaier S, Ngomo ACN, Polleres A, Rashid SM, Rula A, Schmelzeisen L, Sequeda J, Staab S, Zimmermann A (2021) Knowledge graphs. *ACM Comput Surv* 54:1–37
- Hu Y, Zou F, Han J, Sun X, Wang Y (2024) Llm-tikg: threat intelligence knowledge graph construction utilizing large language model. *Comput Secur* 145:103999
- Huang L, Yu W, Ma W, Zhong W, Feng Z, Wang H, Chen Q, Peng W, Feng X, Qin B et al (2025) A survey on hallucination in large language models: principles, taxonomy, challenges, and open questions. *ACM Trans Inf Syst* 43:1–55
- Husari G, Al-Shaer E, Ahmed M, Chu B, Niu X (2017) Ttpdrill: automatic and accurate extraction of threat actions from unstructured text of cti sources. In: Proceedings of the 33rd Annual computer security applications conference, pp 103–115
- Jeon JH, Koo J, Kim YG (2024) Rag-based cyber threat tracing graph modeling method. In: Proceedings of the 23rd IEEE international conference on trust, security and privacy in computing and communications (Trust-Com). IEEE, pp 608–615
- Ji Z, Lee N, Frieske R, Yu T, Su D, Xu Y, Ishii E, Bang YJ, Madotto A, Fung P (2023) Survey of hallucination in natural language generation. *ACM Comput Surv* 55:1–38
- Ji H, Yang J, Chai L, Wei C, Yang L, Duan Y, Wang Y, Sun T, Guo H, Li T et al (2024) Sevenllm: benchmarking, eliciting, and enhancing abilities of large language models in cyber threat intelligence. arXiv preprint [arXiv:2405.03446](https://arxiv.org/abs/2405.03446)
- Jo H, Lee Y, Shin S (2022) Vulcan: automatic extraction and analysis of cyber threat intelligence from unstructured text. *Comput Secur* 120:102763
- Lairgi Y, Moncla L, Cazabet R, Benabdeslem K, Cléau P (2024) itext2kg: incremental knowledge graphs construction using large language models. In: Proceedings of the 2024 international conference on web information systems engineering. Springer, pp 214–229
- Legoy V, Caselli M, Seifert C, Peter A (2020) Automated retrieval of att & ckt tactics and techniques for cyber threat reports. arXiv preprint [arXiv:2004.14322](https://arxiv.org/abs/2004.14322)
- Lewis P, Perez E, Piktus A, Petroni F, Karpukhin V, Goyal N, Küttler H, Lewis M, Yih WT, Rocktäschel T et al (2020) Retrieval-augmented generation for knowledge-intensive nlp tasks. *Adv Neural Inf Process Syst* 33:9459–9474
- Li Z, Zeng J, Chen Y, Liang Z (2022) Attackg: constructing technique knowledge graph from cyber threat intelligence reports. In: Proceedings of the 2022 European symposium on research in computer security. Springer, pp 589–609
- Li Q, Wang Y, Dong J, Zhang C, Peng K (2024a) Multi-node knowledge graph assisted distributed fault detection for large-scale industrial processes based on graph attention network and bidirectional lstms. *Neural Netw* 173:106210
- Li Y, Huang C, Deng S, Lock ML, Cao T, Oo N, Lim HW, Hooi B (2024b) {Know-Phish}: large language models meet multimodal knowledge graphs for enhancing {Reference-Based} phishing detection. In: Proceedings of the 33rd USENIX security symposium (USENIX Security 24), pp 793–810
- Liu J, Zhan J (2023) Constructing knowledge graph from cyber threat intelligence using large language model. In: Proceedings of the 2023 IEEE international conference on big data (BigData). IEEE, pp 516–521
- Liu Y, Ott M, Goyal N, Du J, Joshi M, Chen D, Levy O, Lewis M, Zettlemoyer L, Stoyanov V (2019) Roberta: a robustly optimized bert pretraining approach. arXiv preprint [arXiv:1907.11692](https://arxiv.org/abs/1907.11692)
- Liu S, Li Y, Li J, Yang S, Lan Y (2024) Unleashing the power of large language models in zero-shot relation extraction via self-prompting. arXiv preprint [arXiv:2410.01154](https://arxiv.org/abs/2410.01154)
- Loevenich J, Adler E, Huerten T, Lopes RRF (2025) Design and evaluation of an autonomous cyber defence agent using drl and an augmented llm. *Comput Netw* 262:111162
- Milajerdi SM, Eshete B, Gjomemo R, Venkatakrishnan V (2019) Poirot: aligning attack behavior with kernel audit records for cyber threat hunting. In: Proceedings of the 2019 ACM SIGSAC conference on computer and communications security (CCS), pp 1795–1812
- Mo Y, Liu J, Yang J, Wang Q, Zhang S, Wang J, Li Z (2024) C-icl: contrastive in-context learning for information extraction. arXiv preprint [arXiv:2402.11254](https://arxiv.org/abs/2402.11254)
- Mouiche I, Saad S (2025) Entity and relation extractions for threat intelligence knowledge graphs. *Comput Secur* 148:104120
- Piya FL, Beheshti R (2025) Advancing feature extraction in healthcare through the integration of knowledge graphs and large language models. In: Proceedings of the AAAI conference on artificial intelligence, pp 29293–29294
- Rahimi N, Schuelke-Leech BA, Mirhassani M (2025) A comprehensive review of security vulnerabilities in heavy-duty vehicles: comparative insights and current research gaps. *Comput Secur* 154:104452
- Rajapaksha S, Rani R, Karafili E (2024) A rag-based question-answering solution for cyber-attack investigation and attribution. In: Proceedings of the 2024 European symposium on research in computer security. Springer, pp 238–256

- Ranade P, Piplai A, Joshi A, Finin T (2021) Cybert: contextualized embeddings for the cybersecurity domain. In: Proceedings of the 2021 IEEE international conference on big data (big data). IEEE, pp 3334–3342
- Ren Y, Xiao Y, Zhou Y, Zhang Z, Tian Z (2022) Cskg4apt: a cybersecurity knowledge graph for advanced persistent threat organization attribution. *IEEE Trans Knowl Data Eng* 35:5695–5709
- Satvat K, Gjomemo R, Venkatakrishnan V (2021) Extractor: extracting attack behavior from threat reports. In: Proceedings of the 2021 IEEE European symposium on security and privacy (EuroS &P). IEEE, pp 598–615
- Schwartz Y, Ben-Shimol L, Mimran D, Elovici Y, Shabtai A (2025) Llmcloud-hunter: harnessing llms for automated extraction of detection rules from cloud-based cti. In: Proceedings of the ACM on web conference 2025, pp 1922–1941
- Shi F, Chen X, Misra K, Scales N, Dohan D, Chi EH, Schärli N, Zhou D (2023) Large language models can be easily distracted by irrelevant context. In: Proceedings of the 2023 international conference on machine learning, PMLR, pp 31210–31227
- Shi Z, Li H, Zhao D, Pan C (2024) Research on quality assessment methods for cybersecurity knowledge graphs. *Comput Secur* 142:103848
- Siracusano G, Sanvito D, Gonzalez R, Srinivasan M, Kamatchi S, Takahashi W, Kawakita M, Kakumaru T, Bifulco R (2023) Time for action: automated analysis of cyber threat intelligence in the wild. *arXiv preprint arXiv:2307.10214*
- Srikanth S, Hasanuzzaman M, Meem FT (2024) Evaluating the usability of llms in threat intelligence enrichment. *arXiv preprint arXiv:2409.15072*
- Sufi F (2024) An innovative gpt-based open-source intelligence using historical cyber incident reports. *Nat Lang Process J* 7:100074
- Sun J, Qian S, Han Z, Li W, Qian Z, Yang D, Cao J, Xue G (2025) Lkd-kgc: domain-specific kg construction via llm-driven knowledge dependency parsing. *arXiv preprint arXiv:2505.24163*
- Tang D, Dai R, Zuo C, Chen J, Li K, Qin Z (2025) A low-rate dos attack mitigation scheme based on port and traffic state in sdn. *IEEE Trans Comput* 74(5):1758–1770
- Touvron H, Lavril T, Izacard G, Martinet X, Lachaux MA, Lacroix T, Rozière B, Goyal N, Hambro E, Azhar F et al (2023) Llama: open and efficient foundation language models. *arXiv preprint arXiv:2302.13971*
- Wan Z, Cheng F, Mao Z, Liu Q, Song H, Li J, Kurohashi S (2023) Gpt-re: in-context learning for relation extraction using large language models. *arXiv preprint arXiv:2305.02105*
- Wang Q, Li C, Liu Y, Zhu Q, Song J, Shen T (2025) An adaptive framework embedded with llm for knowledge graph construction. *IEEE Trans Multimed* 27:2912–2923
- Xiong C, Power R, Callan J (2017) Explicit semantic ranking for academic search via knowledge graph embedding. In: Proceedings of the 26th international conference on world wide web, pp 1271–1279
- Xu M, Wang H, Liu J, Lin Y, Liu CXY, Lim HW, Dong JS (2024) Intalex: a llm-driven attack-level threat intelligence extraction framework. *arXiv preprint arXiv:2412.10872*
- Xu H, Si C, Wang C, Sun P, Liu Q et al (2025) Aptsniffer: detecting apt attack traffic using retrieval-augmented large language models. In: Proceedings of the 2025 IEEE international conference on acoustics, speech and signal processing (ICASSP). IEEE, pp 1–5
- Yang X, Peng G, Li Z, Lyu Y, Liu S, Li C (2022) Research on entity recognition and alignment of apt attack based on bert and bilstm-crf. *J Commun* 43:58–70
- Yang X, Peng G, Zhang D, Gao Y, Li C (2023) Powerdetector: malicious powershell script family classification based on multi-modal semantic fusion and deep learning. *China Commun* 20:202–224
- Yang X, Peng G, Liu S, Tian Y, Li C, Fu J (2025) Survey on attribution and inference research for apt attacks. *J Softw* 36:203–252
- Zhang Y, Du T, Ma Y, Wang X, Xie Y, Yang G, Lu Y, Chang EC (2025) Attackg+: boosting attack graph construction with large language models. *Comput Secur* 150:104220
- Zhao X, Jiang R, Han Y, Li A, Peng Z (2024) A survey on cybersecurity knowledge graph construction. *Comput Secur* 136:103524
- Zhou Y, Wang Z, Jiang Y, Ma B, Wang R, Liu Y, Zhao Y, Tian Z (2025) Aekg4apt: an ai-enhanced knowledge graph for advanced persistent threats with large language model analysis. *ACM Trans Intell Syst Technol*

Publisher's Note

Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.